

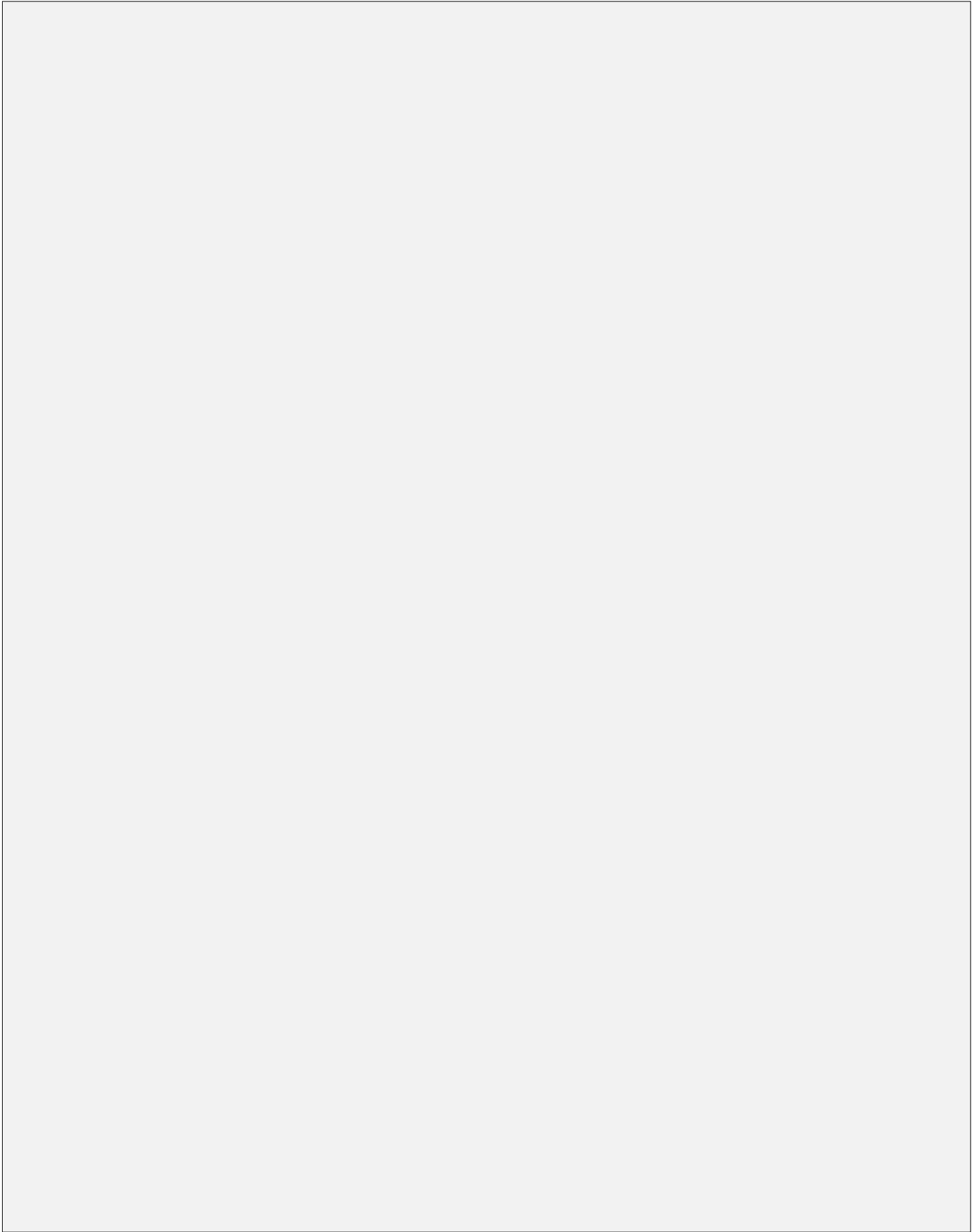


---

신한은행 금융인증서 발급 및 검증 인프라 보안 기획서  
인프라 보안 12기 가디언즈

---

2026. 06. 30



## 목차

|                                |           |                          |           |
|--------------------------------|-----------|--------------------------|-----------|
| <b>1. 개요</b>                   | <b>4</b>  | 5.2.2. 사용자 식별 정책         | 31        |
| 1.1. 수행 목적                     | 4         | 5.2.3. 자격 증명 및 PIN 통제 정책 | 31        |
| 1.2. 수행 일정                     | 4         | 5.2.4. 인증 실행 및 시도 제한 정책  | 31        |
| 1.3. 수행 인력 및 업무(R&R)           | 4         | 5.2.5. 다요소 인증 정책         | 32        |
| 1.4. Ground Rule               | 5         | 5.2.6. 상황 기반 통제 및 세션 정책  | 32        |
| 1.5. WBS                       | 6         | 5.2.7. 보안 운영 및 인증서 관리 정책 | 33        |
| <b>2. 기업 및 서비스 현황</b>          | <b>8</b>  | 5.3. 관리자 계정 정책           | 33        |
| 2.1. 기업 소개                     | 8         | 5.3.1. SSH 관리자 계정 보안 정책  | 33        |
| 2.1.1. 기업 일반 현황                | 8         | 5.3.2. 관리자 페이지 접근 정책     | 33        |
| 2.1.2. 조직 및 인원현황               | 9         | 5.3.3. DB 접근 권한          | 34        |
| 2.2. 웹 서비스 설명                  | 10        | 5.4. 데이터 보호 정책           | 34        |
| 2.2.1. 웹 서비스 주요 기능             | 10        | 5.4.1. HTTPS 적용          | 34        |
| 2.2.2. 예상 사용자 및 트래픽            | 10        | 5.4.2. 개인정보 암호화          | 35        |
| 2.2.3. 서비스 시퀀스 다이어그램           | 11        | 5.4.3. 개인키 관리 정책         | 35        |
| <b>3. 내/외부 인프라 보안 위협 체크리스트</b> | <b>13</b> | 5.4.4. DB 암호화            | 35        |
| 3.1. 웹 취약점 체크리스트               | 13        | 5.5. 암호화 방식 선정 기준        | 36        |
| 3.2. 인프라 위협 사항                 | 14        | 5.6. 보안 관리 정책            | 37        |
| <b>4. 서버 및 네트워크 구성</b>         | <b>23</b> | 5.6.1. 보안 업데이트           | 37        |
| 4.1. 서버 구성                     | 23        | 5.6.2. 블루 그린 배포 방식       | 37        |
| 4.1.1. 전체 서버 구성도               | 23        | 5.6.3. 백업 정책             | 37        |
| 4.1.2. 서버별 상세                  | 25        | 5.6.4. 백업 주기             | 38        |
| 4.2. 네트워크 구성                   | 26        | 5.6.5. 백업 확인             | 38        |
| 4.2.1. 네트워크 다이어그램              | 26        | 5.7. 로그 기록 및 보관 정책       | 39        |
| 4.2.2. 네트워크 구역별 설명             | 27        | 5.7.1. 로그 기록 대상          | 39        |
| 4.2.3. 네트워크 주요 보안 장비           | 27        | 5.7.2. 로그 보관 기간          | 39        |
| <b>5. 보안정책</b>                 | <b>28</b> | 5.7.3. 로그 점검             | 39        |
| 5.1. 접근 제어 정책                  | 28        | 5.7.4. 정기 점검             | 40        |
| 5.1.1. 방화벽 규칙                  | 28        | <b>6. 부록</b>             | <b>41</b> |
| 5.1.2. IP 접근 제어                | 30        | 6.1. 참고 자료               | 41        |
| 5.2. 사용자 인증 및 권한 정책            | 31        | 6.1.1. 보안 기준             | 41        |
| 5.2.1. 개인정보 암호화 정책             | 31        | 6.1.2. 용어 설명             | 41        |
|                                |           | 6.2. OWASP CWE           | 45        |
|                                |           | 6.2.1. 인증서 발급 OWASP CWE  | 45        |
|                                |           | 6.2.2. 인증서 검증 OWASP CWE  | 48        |

# 1 개요

## 1.1. 수행 목적

본 프로젝트는 신한은행의 금융인증 서비스 중 인증서 발급 및 등록, 사용자 인증 및 인증서 상태 검증 기능을 중심으로 웹 기반 인증 인프라를 분석하고 설계하는 것을 목적으로 한다. 금융 서비스에서 인증 절차는 사용자 신원 확인과 데이터 보호를 위한 핵심 보안 요소이므로, 안전하고 신뢰성 있는 인증 체계 구축이 필수적이다.

이에 따라 본 프로젝트에서는 금융인증 서비스의 주요 기능을 구성하는 서버, 네트워크, 데이터 저장소 및 보안 시스템을 설계하고, 인증 과정에서 발생할 수 있는 논리적 취약점을 식별하여 대응 정책을 수립한다. 이를 통해 인프라 설계 능력, 네트워크 설계 능력, 보안 정책 수립 능력 및 협업 기반 프로젝트 수행 역량을 향상시키는 것을 목표로 한다.

## 1.2. 수행 일정

본 프로젝트 기간은 2026년 06월 17일로부터 2026년 07월 01일까지이며 상세 일정은 아래와 같다.

[표 1] 수행 일정

| 구 분         | 일 정       | 세부업무                                 |
|-------------|-----------|--------------------------------------|
| 사전 준비       | 6/17~6/19 | 프로젝트 범위 설정, 역할 분담, 협업 환경 구축 및 WBS 작성 |
| 정보 수집       | 6/18~6/19 | 기업·서비스 조사 및 금융인증 기술(PKI,CRL,OCSP) 분석 |
| 프로젝트 수행     | 6/22~6/26 | 인프라 아키텍처 설계, 위협 분석 및 보안 정책 수립        |
| 보고서 작성 및 제출 | 6/29~6/30 | 산출물 통합, 최종 보고서 작성 및 발표 자료 준비         |

## 1.3. 수행 인력 및 업무(R&R)

본 프로젝트 수행 인력은 인프라보안 12기 인력이 다음과 같은 임무를 수행한다.

[표 2] 수행 인력

| 성명  | 담당 영역          | 목표                              |
|-----|----------------|---------------------------------|
| 노정희 | PM/문서 검수       | 업무 세분화 능력/협업 능력 향상/커뮤니케이션 능력 향상 |
| 박신규 | 시퀀스 제작/OWASP분석 | 금융업계 관련 인프라 설계 능력/협업 능력 향상      |
| 원태현 | OWASP분석/발표     | 협업 능력 향상/커뮤니케이션 능력 향상           |
| 유수연 | 자료조사/용어 정리     | 협업 능력 향상/IT 용어 적응               |
| 피준원 | 서버/네트워크 정리     | 협업 능력 향상/커뮤니케이션 능력 향상           |

## 1.4. Ground Rule

[표 3] Ground Rule

| 구 분    | 상 세                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 커뮤니케이션 | <ul style="list-style-type: none"> <li>- 감정이 격해질 경우 용용체를 사용하여 분위기를 환기한다.</li> <li>- 갈등이나 의견 차이는 개인적으로 해결하지 않고 팀원들과 의논한다.             <ul style="list-style-type: none"> <li>- 모든 이슈와 진행 상황은 즉시 공유한다.</li> <li>- 모르는 것이 있다면 이해될 때까지 질문한다.</li> <li>- 같은 질문이 반복되더라도 성실하게 답변한다.</li> </ul> </li> <li>- 팀원 발언 후 적극적으로 피드백 및 반응을 제공한다.</li> <li>- 상대방의 말을 끊지 않고 끝까지 경청한다.</li> <li>- 말할지 말지 고민이 된다면 일단 지르고 본다.</li> <li>- 부정적인 표현보다는 개선 방안을 함께 생각하고 제시한다.</li> </ul> |
| 회의 규칙  | <ul style="list-style-type: none"> <li>- 음성으로 나온 안건은 댓글로 공유한다.</li> <li>- 회의 시작 및 종료 시간을 준수한다.</li> <li>- 회의록은 반드시 작성하고 공유한다.</li> <li>- 프로젝트 진행 시 서로 zoom 캠을 확인해 준다.</li> <li>- 프로젝트 진행 시 보이스룸은 필수로 참여한다. (의견 제시 시에만 마이크 켜도 ok)</li> <li>- 쉬는 시간/점심 시간은 반드시 지키도록 한다.</li> </ul>                                                                                                                                                                                |
| 업무 규칙  | <ul style="list-style-type: none"> <li>- 담당 업무와 마감 일정을 명확히 공유한다.</li> <li>- 마감 기한을 지키기 어려울 경우 최소 1일 전에 공유한다.</li> <li>- 본인이 맡은 업무 진행 상황을 정기적으로 보고한다.</li> <li>- 산출물 제출 전 본인이 먼저 검토한다.</li> <li>- 팀원의 업무를 대신 수행하기보다 먼저 도움을 요청할 수 있도록 한다.</li> </ul>                                                                                                                                                                                                              |
| 협업 규칙  | <ul style="list-style-type: none"> <li>- 비판보다는 건설적인 의견을 제시한다.</li> <li>- 문제 발생 시 책임 소재를 따지기보다 해결을 우선한다.             <ul style="list-style-type: none"> <li>- 모든 팀원은 의사결정 과정에 참여할 수 있다.</li> </ul> </li> <li>- 결정된 사항은 팀 전체의 합의로 간주하고 존중한다.</li> <li>- 결정에 이상이 생긴다면 강사님께 문의해 본다.</li> </ul>                                                                                                                                                                      |

## 1.5. WBS

[표 4] WBS

| WBS번호 | 작업 제목                     | 담당자      | 1주 |   |   | 2주 |   |   | 3주 |   |   |   |   |
|-------|---------------------------|----------|----|---|---|----|---|---|----|---|---|---|---|
|       |                           |          | 수  | 목 | 금 | 월  | 화 | 수 | 목  | 금 | 월 | 화 | 수 |
| 1     | 프로젝트 기획 및 준비              |          |    |   |   |    |   |   |    |   |   |   |   |
| 1.1   | 프로젝트 주제 확정                | 전체       |    |   |   |    |   |   |    |   |   |   |   |
| 1.2   | 팀원 역할 분담                  | 전체       |    |   |   |    |   |   |    |   |   |   |   |
| 1.3   | Ground Rule 작성            | 전체       |    |   |   |    |   |   |    |   |   |   |   |
| 1.4   | 협업 도구 구축                  | 노정희      |    |   |   |    |   |   |    |   |   |   |   |
| 1.5   | WBS 구축                    | 노정희      |    |   |   |    |   |   |    |   |   |   |   |
| 2     | 대상 기업 분석 및 기능의 요구사항 분석    |          |    |   |   |    |   |   |    |   |   |   |   |
| 2.1   | 기업 소개 조사                  | 피준원      |    |   |   |    |   |   |    |   |   |   |   |
| 2.2   | 예상 트래픽 산정                 | 유수연      |    |   |   |    |   |   |    |   |   |   |   |
| 2.3   | 데이터 흐름 분석                 | 유수연, 피준원 |    |   |   |    |   |   |    |   |   |   |   |
| 2.4   | 기능 범위 조사                  | 박신규, 원태현 |    |   |   |    |   |   |    |   |   |   |   |
| 2.5   | 금융인증서 관련 기술 조사 (PKI,전자서명) | 노정희      |    |   |   |    |   |   |    |   |   |   |   |
| 2.6   | 인증서 발급 절차 조사              | 노정희      |    |   |   |    |   |   |    |   |   |   |   |
| 2.7   | 인증서 검증 절차 조사              | 노정희      |    |   |   |    |   |   |    |   |   |   |   |
| 3     | 인프라 설계 및 취약점 분석           |          |    |   |   |    |   |   |    |   |   |   |   |
| 3.1   | 서버 구성도 초안 설계              | 피준원      |    |   |   |    |   |   |    |   |   |   |   |
| 3.2   | 서비스 아키텍처 초안 작성            | 박신규      |    |   |   |    |   |   |    |   |   |   |   |
| 3.3   | 서버스펙 산정                   | 피준원      |    |   |   |    |   |   |    |   |   |   |   |
| 3.4   | 데이터 저장소 설계                | 박신규, 피준원 |    |   |   |    |   |   |    |   |   |   |   |

|     |                  |          |
|-----|------------------|----------|
| 3.5 | 네트워크 구성도 설계      | 노정희, 피준원 |
| 3.6 | 금융인증서 발급 취약점 분석  | 박신규, 원태현 |
| 3.7 | 금융인증서 검증 취약점 분석  | 박신규, 원태현 |
| 4   | 보안 정책 및 통제 설계    |          |
| 4.1 | 보안 정책 수립         | 박신규, 원태현 |
| 4.2 | 접근 통제 정책 설계      | 피준원      |
| 4.3 | 인증 정책 설계         | 피준원      |
| 4.4 | 키 관리 정책 설계       | 노정희      |
| 4.5 | 로그 관리 정책 설계      | 원태현      |
| 4.6 | 장애 대응 정책 설계      | 원태현      |
| 4.7 | 백업 및 복구 정책 설계    | 원태현, 피준원 |
| 5   | 최종 산출물 작성        |          |
| 5.1 | 보고서 초안 작성        | 노정희      |
| 5.2 | 최종 인프라 아키텍처 작성   | 노정희      |
| 5.3 | 최종 네트워크 다이어그램 작성 | 노정희      |
| 5.4 | 정책 문서 정리         | 노정희      |
| 5.5 | 보고서 검토 및 수정      | 전체       |
| 6   | 최종 제출 및 발표       |          |
| 6.1 | 발표 자료 제작         | 전체       |
| 6.2 | 발표 리허설           | 전체       |
| 6.3 | 최종 보고서 제출        | 노정희      |
| 6.4 | 최종 발표            | 원태현      |

2

기업 및 서비스 현황

2.1. 기업 소개

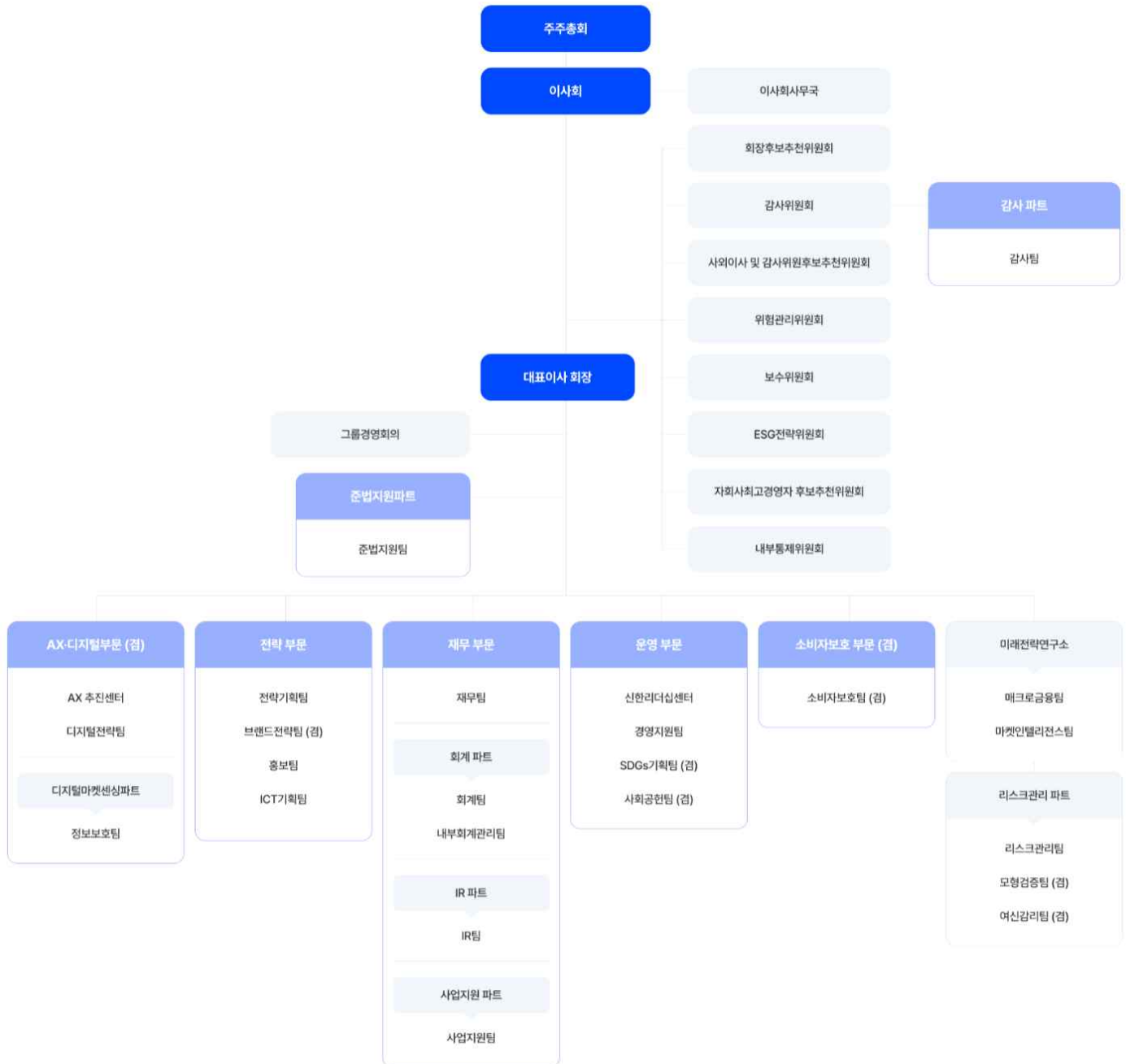
2.1.1. 기업 일반 현황

[표 5] 기업 현황

| 구분       | 내용                               |
|----------|----------------------------------|
| 회사명      | 신한은행                             |
| 설립연도     | 1943년 (조흥은행 법인 기준)               |
| 사업 분야    | 은행업, 금융서비스, 디지털 뱅킹               |
| 직원 수     | 약 12,300명                        |
| 본사 위치    | 서울특별시 중구 세종대로 20                 |
| 연 매출     | 약 36조 6,100억 원 (2025년 별도 매출액 기준) |
| 영업이익     | 약 5조 3,000억 원 (2025년 기준)         |
| 회원 수     | 약 2,100만 명                       |
| 일 평균 방문자 | 약 11만~15만 명 (추정)                 |
| 주요 고객    | 개인 금융 고객, 기업 고객, 공공기관 및 금융 파트너사  |

## 2.1.2. 조직 및 인원현황

[그림1] 신한금융 조직도



## 2.2. 웹 서비스 설명

### 2.2.1. 웹 서비스 주요 기능

[표 6] 주요 기능

| 기능 분류     | 세부 기능              | 설명                                      |
|-----------|--------------------|-----------------------------------------|
| 금융 인증서 관리 | 금융인증서 발급 및 등록      | 사용자 본인 인증<br>인증수단을 통해 사용자의 신원을 확인한다.    |
|           |                    | 인증서 생성<br>공개키·개인키를 생성하여 금융인증서를 발급한다.    |
|           |                    | 인증서 저장 및 등록<br>발급된 인증서를 저장소에 등록하여 관리한다. |
|           | 사용자 인증 및 인증서 상태 검증 | 전자서명 검증<br>전자서명의 진위 여부와 무결성을 검증한다.      |
|           |                    | CRL<br>폐기 인증서 목록을 조회하여 상태를 확인한다.        |
|           |                    | OCSP<br>인증서의 유효 상태를 실시간으로 검증한다.         |

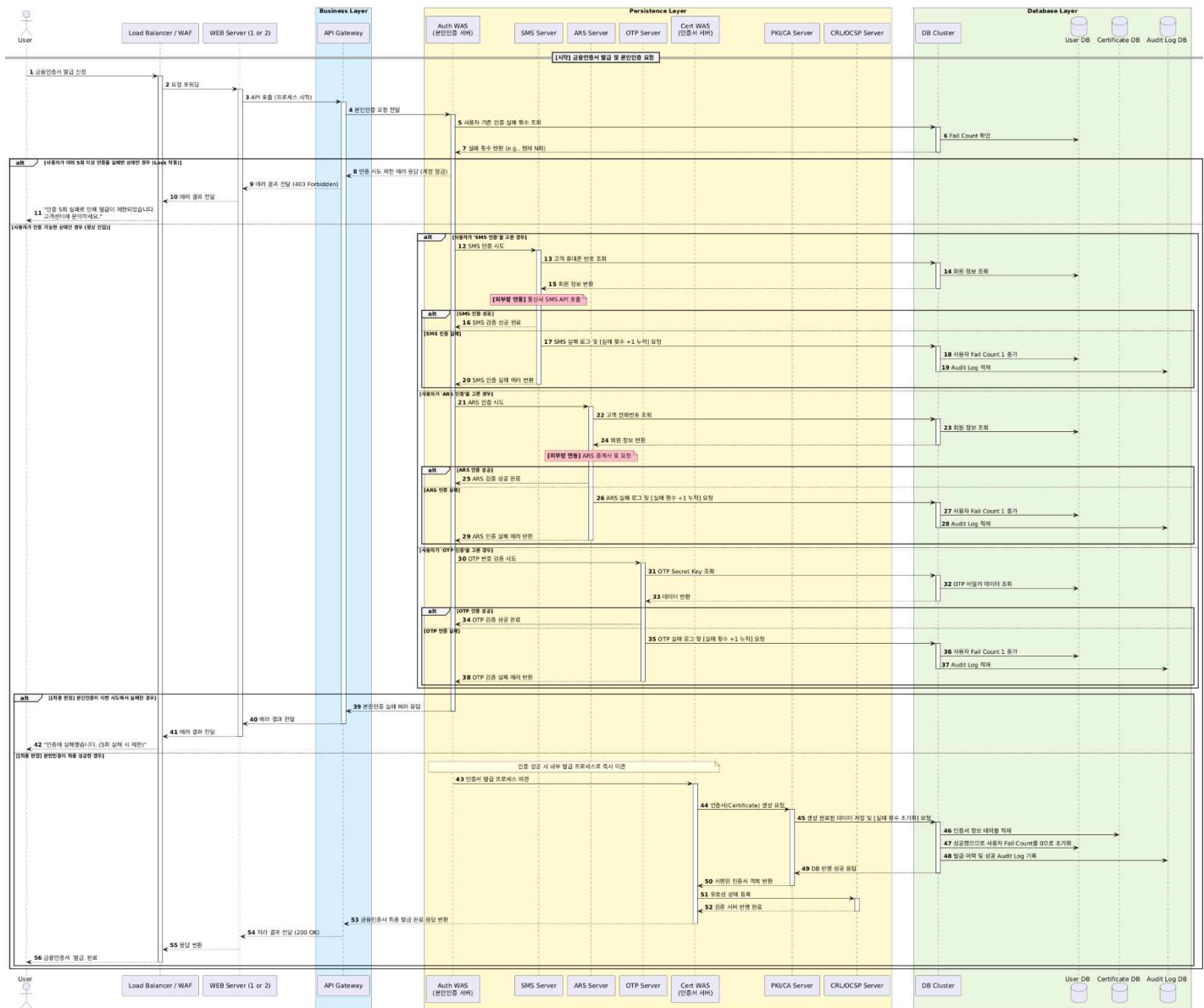
### 2.2.2. 예상 사용자 및 트래픽

[표 7] 이용자 수

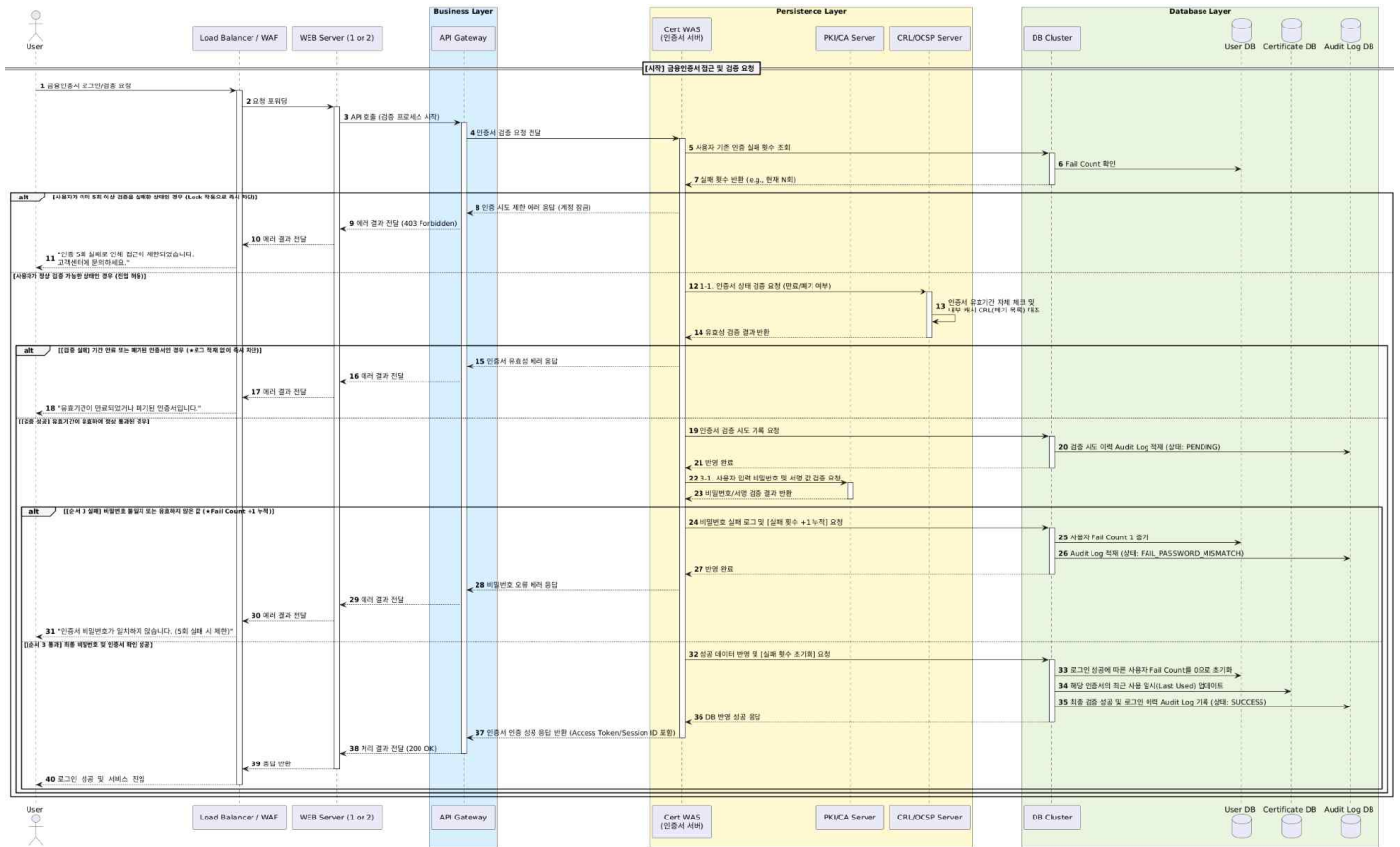
| 구분  | 항목          | 수치            |
|-----|-------------|---------------|
| 사용자 | 총 회원 수      | 2,000만명       |
|     | 일 평균 방문자    | 13만명          |
|     | 평균 동시 접속    | 990만명         |
|     | 피크 시 동시 접속자 | 8만명~15만명      |
|     | 일 평균 주문 건수  | 3만건~5만건       |
| 트래픽 | 일 평균 트래픽    | 50만건          |
|     | 피크 시간       | 오전11시30분~오후2시 |
|     | 이벤트 시 트래픽   | 30만명~50만명     |

## 2.2.3. 서비스 시퀀스 다이어그램

[그림2] 금융인증서 발급 시퀀스 다이어그램



[그림3] 금융인증서 검증 시퀀스 다이어그램



### 3 내/외부 인프라 보안 위협 체크리스트

#### 3.1. 웹 취약점 체크리스트

이행점검 기준은 2025년 OWASP TOP10을 기준으로 점검하며, 상세 점검항목은 아래와 같다.

금융인증 서비스는 인증서 기반 사용자 인증 및 민감 정보 처리를 수행하므로, OWASP Top 10 중 특히 접근 제어 오류(A-01), 암호화 오류(A-04), 인증 실패(A-07), 무결성 오류(A-08)가 핵심 위험 요소로 판단된다.

[표 8] 웹 어플리케이션 점검 항목

| 코드  | 점검항목                                                         | 설명                                                 | 위험도 |
|-----|--------------------------------------------------------------|----------------------------------------------------|-----|
| A01 | Broken Access Control<br>(접근 제어 오류)                          | 사용자 또는 관리자가 허용된 권한 범위를 벗어나 시스템 자원에 접근할 수 있는 취약점    | 치명적 |
| A02 | Security Misconfiguration<br>(보안 설정 오류)                      | 서버, 애플리케이션, 클라우드 환경의 잘못된 설정으로 인해 보안 취약점이 발생하는 경우   | 중~상 |
| A03 | Software Supply Chain Failures<br>(소프트웨어 공급망 실패)             | 소프트웨어 개발, 배포, 업데이트 과정에서 외부 구성 요소를 통해 취약점이 유입되는 경우  | 중   |
| A04 | Cryptographic Failures<br>(암호화 실패)                           | 민감한 데이터가 적절히 암호화되지 않거나 약한 암호 알고리즘을 사용하는 취약점        | 치명적 |
| A05 | Injection<br>(인젝션)                                           | 악성 입력값이 명령어-쿼리로 해석되어 의도하지 않은 작업이 수행되는 취약점          | 상   |
| A06 | Insecure Design<br>(안전하지 않은 설계)                              | 설계 단계에서 보안 요구사항이 충분히 고려되지 않아 구조적으로 발생하는 취약점        | 상   |
| A07 | Authentication Failures<br>(인증 실패)                           | 사용자 인증 또는 세션 관리가 미흡하여 인증 우회가 가능한 취약점               | 치명적 |
| A08 | Software or Data Integrity Failures<br>(소프트웨어 또는 데이터 무결성 실패) | 코드, 소프트웨어, 업데이트 파일, 데이터의 무결성 검증이 부족해 위·변조가 가능한 취약점 | 치명적 |
| A09 | Security Logging and Alerting Failures<br>(보안 로깅 및 경고 실패)    | 보안 이벤트 기록 및 모니터링이 부족해 공격 탐지와 대응이 어려운 취약점           | 중   |
| A10 | Mishandling of Exceptional Conditions<br>(예외 상황 처리 실패)       | 오류 처리나 비정상 상황 대응이 부적절하여 정보 노출 또는 서비스 장애가 발생하는 취약점  | 중   |

### 3.2. 인프라 위협 사항

[표 9] 인증서 발급 인프라 위협 사항 - 경영진용 요약표

| 위협유형   | 구체적 위협                      | 영향도 | 대응방안                    |
|--------|-----------------------------|-----|-------------------------|
| 외부 공격  | A01 API 인증 우회               | 치명적 | API 인증 및 권한 검증          |
|        | A02 SMS/ARS 평문 통신           | 상   | TLS 및 데이터 암호화           |
|        | A03 취약 OTP-인증서 모듈           | 치명적 | 패치 및 SBOM 관리            |
|        | A04 인증서 위변조                 | 상   | 전자서명 및 무결성 검증           |
|        | A05 Injection / 입력값 조작      | 상   | 화이트리스트 및 필터링            |
|        | A06 Replay / Race Condition | 치명적 | One-Time Token, DB Lock |
|        | A07 인증 정책 우회                | 상   | Fail Count 및 세션 재검증     |
|        | A08 데이터 변조                  | 치명적 | CSR 검증, mTLS            |
|        | A09 로그 위변조                  | 치명적 | Append-Only, SIEM       |
|        | A10 예외처리 오류 악용              | 상   | Safe-Fail, Timeout Fail |
| 내부위협   | 권한 오남용                      | 치명적 | RBAC 및 최소 권한 적용         |
|        | 내부자 악성 행위                   | 치명적 | MFA, HSM, 감사 로그 적용      |
|        | 운영 실수                       | 상   | 변경 승인 및 설정 검증           |
| 물리적 위협 | 분실·도난                       | 상   | 단말 보호 및 추가 인증           |
|        | 저장매체 탈취                     | 치명적 | 저장소 암호화 및 출입 통제         |
|        | 시설 장애                       | 상   | UPS, DR 센터 및 환경 모니터링    |

[표 10] 인증서 발급 인프라 위협 사항 - 상세표

| 위협유형  | 구체적 위협 |                                                                           | 영향도 | 대응방안             |
|-------|--------|---------------------------------------------------------------------------|-----|------------------|
| 외부 공격 | A01    | [3] API 호출 (프로세스 시작)<br>ex) API 인증 검증 미흡으로 인증 우회                          | 치명적 | API 인증 및 권한 검증   |
|       |        | [43] 인증서 발급 프로세스 이관<br>ex) 발급 단계 권한 검증 누락으로 절차 우회                         | 치명적 | 세션 인증 상태 재검증     |
|       | A02    | [15] 회원 정보 반환<br>(외부망 연동: 통신사 SMS API 호출)<br>ex) SMS 연계구간 평문 통신으로 개인정보 노출 | 상   | TLS 및 데이터 암호화    |
|       |        | [24] 회원 정보 반환<br>(외부망 연동: ARS 중계사 호 요청)<br>ex) ARS 연계구간 평문 통신으로 개인정보 노출   | 상   | TLS 및 데이터 암호화    |
|       |        | [53] 금융인증서 최종 발급 완료 응답 반환<br>ex) 발급 결과 평문 전송으로 인증 정보 노출                   | 상   | HTTPS 및 페이로드 암호화 |
|       | A03    | [30] OTP 번호 검증 시도<br>ex) 취약한 OTP 모듈 사용으로 서버 침해                            | 치명적 | 보안 패치 및 버전 관리    |
|       |        | [44] 인증서(Certificate) 생성 요청<br>ex) 취약한 인증서 모듈로 암호키 유출                     | 치명적 | 종속성 무결성 검증       |
|       | A04    | [31] OTP Secret Key 조회<br>ex) 취약한 키 관리로 Secret Key 노출                     | 상   | 안전한 키 관리 적용      |
|       |        | [44] 인증서(Certificate) 생성 요청<br>ex) 인증 요청 무결성 검증 누락으로 위조 발급                | 상   | 전자서명 검증          |
|       |        | [45] 생성 완료된 데이터 저장 및<br>실패 횟수 초기화 요청<br>ex) 취약 알고리즘 사용으로 인증서 위변조          | 상   | 안전한 암호 알고리즘 적용   |
|       | A05    | [3] API 호출 (프로세스 시작)<br>ex) 과도한 API 요청으로 서비스 마비                           | 상   | 요청 크기 제한         |
|       |        | [4] 본인인증 요청 전달<br>ex) 입력값 검증 미흡으로 비정상 데이터 처리                              | 상   | 화이트리스트 검증        |
|       |        | [4] 본인인증 요청 전달<br>ex) LDAP Injection으로 인증 우회                              | 상   | 입력값 필터링          |

|       |     |                                                      |     |                      |
|-------|-----|------------------------------------------------------|-----|----------------------|
| 외부 공격 | A06 | [3] API 호출 (프로세스 시작)<br>ex) 직접 API 호출로 인증 절차 우회      | 상   | 원타임 토큰 및 Referrer 검증 |
|       |     | [6] Fail Count 확인<br>ex) DB 오류 시 계정 잠금 우회            | 상   | Fail-Closed 정책 적용    |
|       |     | [12] SMS 전송 시도<br>ex) 문자 폭탄 및 비용 유발 공격               | 중   | Rate Limit 적용        |
|       |     | [21] ARS 인증 시도<br>ex) SMS→ARS 전환으로 제한 우회             | 상   | 통합 Fail Count 관리     |
|       |     | [32] OTP Secret Key 조회<br>ex) 타인 OTP로 인증 우회          | 치명적 | User ID + OTP 교차 검증  |
|       |     | [43] 인증서 발급 프로세스 이관<br>ex) Replay 공격으로 중복 발급         | 치명적 | One-Time Token 적용    |
|       |     | [47] 사용자 Fail Count 초기화<br>ex) 발급 성공 후 상태 불일치        | 상   | 트랜잭션 롤백 적용           |
|       | A07 | [6] Fail Count 확인<br>ex) 유효하지 않은 ID로 인증 진입           | 상   | 계정 존재 여부 선검증         |
|       |     | [8] 인증 시도 제한 정책 (계정 잠금)<br>ex) 세션 변경 후 무차별 대입        | 상   | 계정/IP 기준 누적 제한       |
|       |     | [30] OTP 번호 검증 시도<br>ex) 성공 OTP 재사용                  | 상   | 사용 완료 처리             |
|       |     | [43] 인증서 발급 프로세스 이관<br>ex) 세션 고정 공격                  | 치명적 | 인증 후 세션 재생성          |
|       | A08 | [15] 회원 정보 반환<br>ex) 중간 데이터 변조                       | 상   | 데이터 무결성 검증           |
|       |     | [24] 회원 정보 반환 (ARS)<br>ex) 조작된 데이터 주입                | 상   | 스키마 검증 적용            |
|       |     | [44] 인증서 생성 요청<br>ex) 위조 인증서 발급                      | 치명적 | CSR 서명 검증            |
|       |     | [51] 유효성 상태 등록<br>ex) 인증서 상태 변조                      | 상   | mTLS 및 무결성 토큰        |
|       | A09 | [11] "인증 5회 실패로 인해..." 에러 결과 전달<br>ex) 공격 발생 후 탐지 실패 | 상   | SIEM 실시간 알림          |
|       |     | [19] Audit Log 적재 (SMS 실패 로그)<br>ex) 로그 인젝션          | 중   | 특수문자 필터링             |

|       |           |                                                             |     |                            |
|-------|-----------|-------------------------------------------------------------|-----|----------------------------|
| 외부 공격 | A09       | [28] Audit Log 적재 (ARS 실패 로그)<br>ex) 추적 및 IP 차단 불가          | 상   | IP-시간-기기 기록                |
|       |           | [37] Audit Log 적재 (OTP 실패 로그)<br>ex) 로그 분석 오류               | 중   | NTP 동기화                    |
|       |           | [48] 발급 이력 및 성공 Audit Log 기록<br>ex) 공격 흔적 삭제                | 치명적 | Append-Only 저장             |
|       | A10       | [11] 에러 결과 전달<br>ex) 계정 잠금 우회                               | 상   | Safe-Fail 적용               |
|       |           | [20] SMS 인증 실패 에러 반환<br>ex) 내부 구조 정보 노출                     | 상   | 표준 에러 메시지                  |
|       |           | [25] ARS 상태 로그 및 에러 처리<br>ex)오류 시 인증 우회                     | 치명적 | 기본값 false 설정               |
|       |           | [34] OTP 검증 결과 오류 처리<br>ex) 장애 시 인증 우회                      | 치명적 | Timeout=실패 처리              |
|       |           | [40] 에러 결과 전달 (최종 실패 응답)<br>ex) 커넥션 누수로 서버 다운               | 상   | 자동 자원 해제                   |
| 내부 위협 | 권한 오남용    | 사용자 정보 조회 권한 적정성<br>ex) 운영자가 업무와 무관하게 사용자 개인정보를 조회          | 상   | RBAC 적용 및 최소 권한 부여         |
|       |           | ARS 인증 대상 정보 조회 권한 통제<br>ex) 내부 직원이 ARS 대상 개인정보 무단 열람       | 상   | 데이터 마스킹 및 직무별 권한 분리        |
|       |           | 인증서 DB 접근 통제 여부<br>ex) 발급 이력 및 폐기 정보 임의 조회·수정               | 치명적 | DB 계정 분리 및 최소 권한 적용        |
|       |           | Audit Log 접근 권한 통제<br>ex)관리자가 감사 로그를 삭제·변조하여 흔적 은폐          | 치명적 | Append-Only 저장소 및 삭제 권한 차단 |
|       | 내부자 악성 행위 | Fail Count 수정 권한 통제<br>ex) 내부 관리자가 Fail Count를 조작해 계정 잠금 우회 | 상   | 변경 권한 제한 및 감사 로그 기록        |
|       |           | 발급 프로세스 실행 권한 통제<br>ex) 관리자 계정 탈취 후 비인가 인증서 발급              | 치명적 | 관리자 MFA 및 승인 워크플로우         |
|       |           | 인증서 생성 요청 권한 검증<br>ex) 승인 없는 인증서 생성 요청 수행                   | 치명적 | 발급 요청 권한 검증 및 이중 승인        |
|       |           | OTP Secret Key 접근 통제<br>ex) Secret Key 복사 후 OTP 위조          | 치명적 | HSM 저장 및 키 접근 통제           |

|        |           |                                                             |     |                                |
|--------|-----------|-------------------------------------------------------------|-----|--------------------------------|
| 내부 위협  | 내부자 악성 행위 | 인증서 생성 시 암호키 보호<br>ex) 개인키 유출로 위조 인증서 생성                    | 치명적 | HSM 및 키 순환 정책 적용               |
|        |           | PKI Server 관리자 접근 통제<br>ex) 관리자샐 접근으로 루트 권한 탈취 및 키 추출       | 치명적 | Bastion 서버 및 명령 감사 로그 적용       |
|        | 운영 실수     | SMS 인증 모듈 관리<br>ex) 승인되지 않은 구버전 모듈 운영                       | 중   | 버전 관리 및 정기 패치                  |
|        |           | ARS 인증 모듈 무결성 검증<br>ex) 변조된 SDK가 악성 번호로 인증 요청 전송            | 상   | 해시 검증 및 무결성 점검                 |
|        |           | OTP 서버 모듈 변경 이력 관리<br>ex) 검증되지 않은 OTP 로직 배포                 | 상   | 변경 승인 및 배포 이력 관리               |
|        |           | 인증 데이터 무결성 검증<br>ex) 다른 사용자 인증 결과가 혼합됨                      | 상   | 사용자 식별 값 교차 검증                 |
|        |           | 인증서 저장 데이터 암호화<br>ex) 인증서 및 키가 평문 저장됨                       | 치명적 | AES-256 암호화 저장                 |
| 물리적 위협 | 분실·도난     | SMS-ARS-OTP 수신 단말 보관 관리<br>ex) 분실된 휴대폰이나 OTP 기기로 인증 수행      | 상   | SIM Lock, 화면 잠금, 분실 신고 및 원격 잠금 |
|        | 저장 매체 탈취  | OTP Secret Key 저장 장치 보호<br>ex) Secret Key 저장 장치 탈취 후 OTP 위조 | 치명적 | HSM 또는 암호화 저장 (AES-256), 접근 통제 |
|        |           | 인증서 저장소 물리적 접근 통제<br>ex) 인증서 저장 장치 도난·훼손                    | 치명적 | 서버실 출입 통제, CCTV, 출입 기록 감사      |
|        |           | DB 서버 물리적 보안<br>ex) 비인가자의 서버 침입 및 저장 매체 탈취                  | 치명적 | 생체인증·출입카드 기반 이중 잠금             |
|        |           | PKI 장비 보호<br>ex) CA 개인키 저장 장비 탈취로 위조 인증서 발급                 | 치명적 | HSM 격리, Tamper Detection 적용    |
|        | 시설 장애     | 화재 대응 체계<br>ex) 화재로 서버 및 저장 장치 손상                           | 치명적 | 소화 설비, 내화 구역, 정기 점검            |
|        |           | 전원 장애 대응<br>ex) 정전으로 인증/발급 서비스 중단                           | 상   | UPS 및 이중 전원 구성                 |
|        |           | 온습도 관리<br>ex) 과열로 서버 장애 및 데이터 손상                            | 상   | 항온항습 시스템 및 온도 모니터링             |
|        |           | 보조배터리·전원 장치 안전성<br>ex) 불량 배터리 과열로 화재 발생                     | 중   | KC 인증 장비 사용 및 충전 관리            |

[표 11] 인증서 검증 인프라 위협 사항 - 경영진용 요약표

| 위협유형   | 구체적 위협                      | 영향도 | 대응방안               |
|--------|-----------------------------|-----|--------------------|
| 외부 공격  | A01 위조 토큰/API 호출            | 상   | API 인증 및 세션 검증     |
|        | A02 CRL/세션 통신 도청            | 상   | TLS/mTLS           |
|        | A03 악성 PKI 모듈               | 상   | 모듈 서명 검증           |
|        | A04 위조 인증서 검증 통과            | 치명적 | Chain of Trust     |
|        | A05 SQL Injection           | 상   | Prepared Statement |
|        | A06 Replay / Fail-Closed 우회 | 치명적 | Nonce, Fail-Closed |
|        | A07 무차별 대입 / 세션 고정          | 치명적 | Fail Count, 세션 재발급 |
|        | A08 검증 데이터 변조               | 치명적 | HMAC 및 무결성 검증      |
|        | A09 로그 은닉                   | 중   | SIEM 및 중앙 로그       |
|        | A10 SSRF / 라우팅 변조           | 치명적 | 고정 라우팅 및 방화벽       |
| 내부위협   | 권한 오남용                      | 상   | RBAC 및 권한 분리       |
|        | 내부자 악성 행위                   | 치명적 | 접근 통제 및 감사 로그      |
|        | 운영 실수                       | 상   | 설정 검증 및 변경 관리      |
| 물리적 위협 | 분실·도난                       | 상   | 단말 보호 및 추가 인증      |
|        | 저장매체 탈취                     | 치명적 | 저장소 암호화 및 접근 통제    |
|        | 시설 장애                       | 중   | UPS 및 DR 센터 구축     |

[표 12] 인증서 검증 인프라 위협 사항 - 상세표

| 위협유형  | 구체적 위협 |                                                               | 영향도 | 대응방안               |
|-------|--------|---------------------------------------------------------------|-----|--------------------|
| 외부 공격 | A01    | [3] API 호출 (검증 프로세스 시작)<br>ex) 위조 토큰 API 호출                   | 상   | API 인증 및 권한 검증     |
|       |        | [5] 사용자 기존 인증 실패 횟수 조회<br>ex) 타인 계정 상태 조회                     | 상   | 세션·사용자 매핑 검증       |
|       |        | [38] 처리 결과 전달 (200 OK)<br>ex) 응답값 변조 권한 우회                    | 치명적 | 서버 세션 인가 검증        |
|       | A02    | [12] 인증서 상태 검증 요청 (만료/폐기 여부)<br>ex) 서버 간 평문 통신 도청             | 상   | TLS/mTLS 적용        |
|       |        | [13] 인증서 유효기간 자체 체크 및 내부 캐시 CRL(폐기 목록) 대조<br>ex) 변조된 CRL 사용   | 상   | CRL 전자 서명 검증       |
|       |        | [36] DB 반영 성공 응답<br>ex) 쿠키 스니핑으로 세션 탈취                        | 상   | Secure/HttpOnly 설정 |
|       | A03    | [12] 외부 연동 검증 모듈(PKI/CA)의 무결성 및 출처 검증 여부<br>ex) 악성 PKI 모듈 유입  | 상   | 모듈 서명 검증           |
|       |        | [13] 다운로드 배포 데이터(CRL)의 무결성 검증 여부<br>ex) 변조된 CRL 파일 사용         | 중   | 해시 및 서명 검증         |
|       |        | [22] 사용자 입력 비밀번호 및 서명 값 검증 요청<br>ex) 취약 라이브러리로 검증 우회          | 상   | SBOM 기반 패치 관리      |
|       | A04    | [12] 인증서 상태 검증 요청 (만료/폐기 여부)<br>ex) 위조·만료 인증서 신뢰              | 치명적 | Chain of Trust 검증  |
|       |        | [13] 인증서 유효기간 자체 체크 및 내부 캐시 CRL(폐기 목록) 대조<br>ex) 서명 조작 인증서 통과 | 치명적 | Signature 검증 강제    |

|       |     |                                                                       |     |                        |
|-------|-----|-----------------------------------------------------------------------|-----|------------------------|
| 외부 공격 | A04 | [37] 인증서 인증 성공 응답 반환 (Access Token/Session ID 포함)<br>ex) 예측 가능한 토큰 생성 | 중   | CSPRNG 사용              |
|       | A05 | [6] Fail Count 확인<br>ex) SQL Injection으로 DB 노출                        | 상   | Prepared Statement 적용  |
|       |     | [22] 사용자 입력 비밀번호 및 서명 값 검증 요청<br>ex) 특수 구문 주입으로 로직 우회                 | 상   | 화이트리스트 및 길이 검증         |
|       |     | [1] 금융인증서 로그인/검증 요청<br>ex) 클라이언트 데이터 재검증 미흡으로 타인 인증서 로그인 우회           | 상   | 세션-사용자 교차검증            |
|       | A06 | [6] Fail Count 확인<br>ex) DB 오류 시 로그인 제한 우회                            | 치명적 | Fail-Closed 정책 적용      |
|       |     | [12] 인증서 상태 검증 요청<br>ex) 검증 서버 장애 시 폐기 인증서 통과                         | 상   | 검증 실패 시 인증 실패 처리       |
|       |     | [22] 비밀번호 및 서명 값 검증 요청<br>ex) Replay 공격으로 인증 우회                       | 치명적 | Nonce 및 타임스탬프 적용       |
|       |     | [24] 실패 횟수 +1 누적 요청<br>ex) Race Condition 우회                          | 상   | DB Lock 및 원자적 연산 적용    |
|       | A07 | [5] 인증 실패 횟수 조회<br>ex) 무차별 대입 우회                                      | 상   | 사용자 계정 별 Fail Count 관리 |
|       |     | [12] 인증서 상태 검증 요청<br>ex) 타인 인증서 사용                                    | 치명적 | 사용자 정보와 인증서 정보 비교      |
|       |     | [22] 비밀번호 및 서명 값 검증 요청<br>ex) 인증 패킷 재사용                               | 치명적 | 일회성 난수 기반 검증           |
|       |     | [37] 인증 성공 응답 반환<br>ex) 세션 고정(Session Fixation) 공격                    | 상   | 인증 성공 후 세션 재발급         |
|       | A08 | [12] 인증서 상태 검증 요청<br>ex) 검증 데이터 변조                                    | 치명적 | TLS 및 HMAC 적용          |

|       |           |                                                         |     |                   |
|-------|-----------|---------------------------------------------------------|-----|-------------------|
| 외부 공격 | A08       | [22] 비밀번호 및 서명 값 검증 요청<br>ex) 서명 위조                     | 치명적 | 안전한 암호 알고리즘 적용    |
|       |           | [32] 성공 데이터 반영 및 Fail Count 초기화 요청<br>ex) Fail Count 조작 | 상   | 입력값 검증 및 트랜잭션 강화  |
|       | A09       | [20] Audit Log 적재 (PENDING)<br>ex) 로그 내 인증정보 평문 노출      | 상   | 민감정보 마스킹 및 해시 처리  |
|       |           | [26] Audit Log 적재 (FAIL)<br>ex) 로그 위변조로 공격 흔적 삭제        | 중   | Append-Only 저장 적용 |
|       |           | [35] 로그인 성공 Audit Log 기록<br>ex) 이상 로그인 미탐지              | 중   | SIEM 실시간 알림 연계    |
|       | A10       | [4] 인증서 검증 요청 전달<br>ex) 라우팅 변조                          | 치명적 | 고정 라우팅 테이블 사용     |
|       |           | [12] 인증서 상태 검증 요청<br>ex) 내부 주소 변조                       | 치명적 | 고정 설정 및 방화벽 적용    |
| 내부 위협 | 권한 오남용    | 인증서 정보 조회 권한 검증 여부<br>ex) 고객 인증서 무단 조회                  | 상   | RBAC 적용 및 권한 분리   |
|       |           | Fail Count 수정 권한 통제 여부<br>ex) Fail Count 임의 초기화         | 상   | 변경 권한 제한 및 감사     |
|       |           | Access Token 발급 권한 검증 여부<br>ex) 토큰 임의 발급                | 치명적 | 권한 분리 및 승인 절차     |
|       |           | Last Used 수정 권한 통제 여부<br>ex) 로그인 이력 조작                  | 상   | 변경 이력 감사          |
|       |           | 감사 로그 열람 권한 통제 여부<br>ex) 감사 로그 무단 열람                    | 중   | 열람 권한 최소화         |
|       | 내부자 악성 행위 | 인증서 비밀번호 저장 데이터 암호화 여부<br>ex) 감사 로그 무단 열람               | 치명적 | 해시 저장 및 암호화       |
|       |           | CRL/OCSP 응답 변경 권한 통제 여부<br>ex) 감사 로그 무단 열람              | 치명적 | 서명 검증 및 무결성 검사    |
|       |           | Access Token 저장 데이터 보호 여부<br>ex) 감사 로그 무단 열람            | 치명적 | 토큰 암호화 및 접근 통제    |
|       |           | 비밀번호 검증 로직 변경 통제 여부<br>ex) 인증 우회 코드 삽입                  | 치명적 | 코드 리뷰 및 형상관리      |
|       |           | Audit Log 삭제·변조 방지 여부<br>ex) 감사 로그 삭제·변조                | 치명적 | WORM 저장소 및 중앙 관리  |

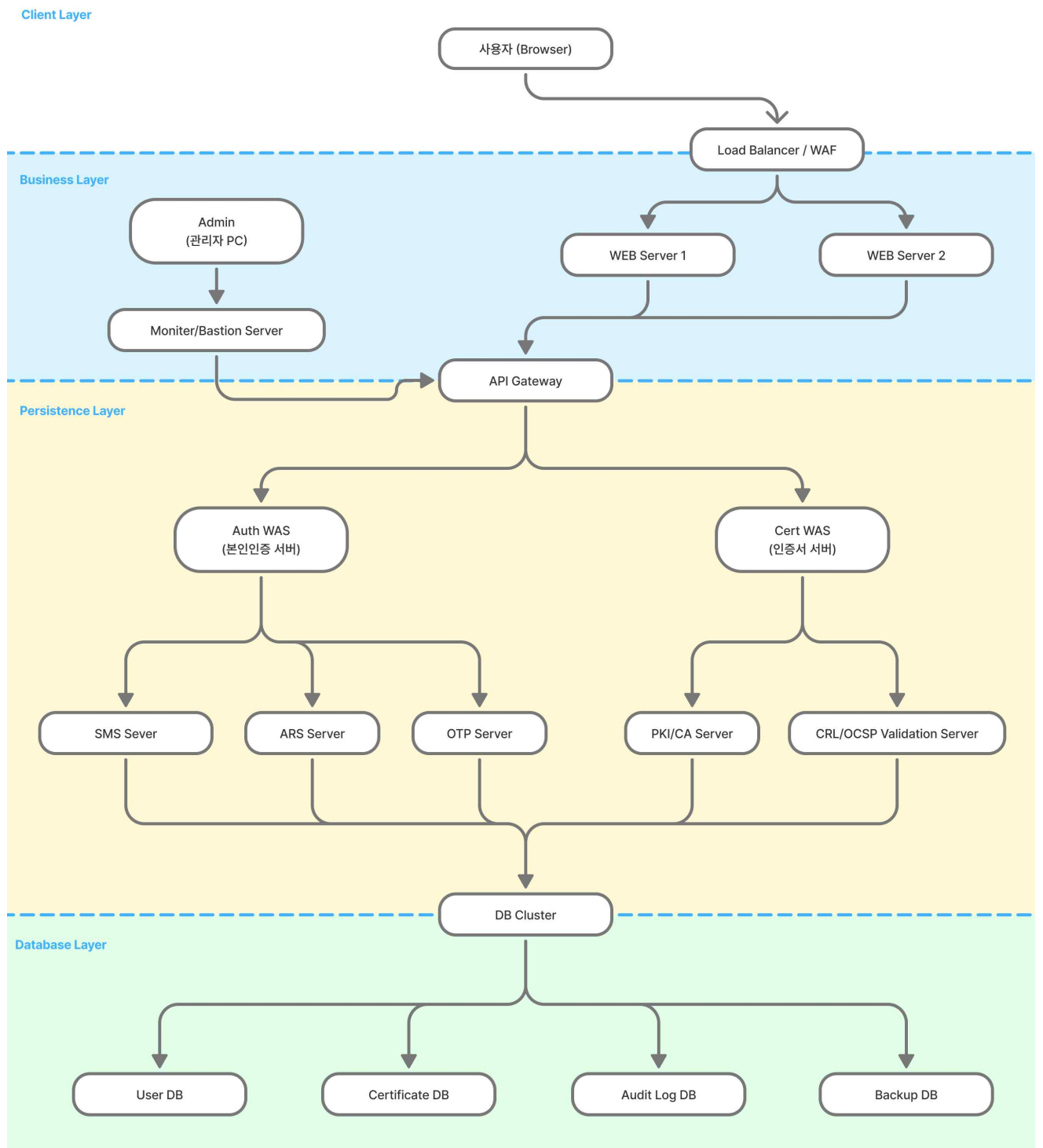
|        |           |                                                |     |                             |
|--------|-----------|------------------------------------------------|-----|-----------------------------|
| 내부 위협  | 내부자 악성 행위 | CRL/OCSP 캐시 갱신 권한 통제 여부<br>ex) 폐기 목록 갱신 중단     | 치명적 | 권한 분리 및 갱신 모니터링             |
|        | 운영 실수     | 인증서 조회 입력값 검증 여부<br>ex) 입력값 검증 누락              | 상   | 입력값 검증 및 Prepared Statement |
|        |           | 인증 요청 파라미터 검증 여부<br>ex) 검증 파라미터 누락             | 상   | 서버측 검증                      |
|        |           | 오류 메시지 노출 통제 여부<br>ex) 상세 오류 정보 노출             | 중   | 표준 에러 메시지 적용                |
|        |           | 인증 실패 로그 누락 방지 여부<br>ex) 실패 로그 미기록             | 상   | Audit Log 의무화               |
|        |           | Access Token 만료 정책 변경 통제 여부<br>ex) 토큰 만료 설정 오류 | 상   | 설정 감사 및 승인 절차               |
| 물리적 위협 | 분실·도난     | 사용자 단말 물리적 보호 여부<br>ex) 단말 분실로 인증서 탈취          | 상   | 저장소 암호화 및 추가 인증 적용          |
|        |           | 승인되지 않은 장치 연결 통제 여부<br>ex) 불법 장치 연결로 내부망 침입    | 상   | 자산 식별 및 포트 접근 통제            |
|        |           | 공급망 무결성 검증 여부<br>ex) 변조 장비 반입                  | 상   | 공급망 검증 및 무결성 검사             |
|        | 저장 매체 탈취  | 비밀번호 저장 DB 물리적 보호 여부<br>ex) DB 저장 매체 탈취        | 상   | 출입 통제 및 KMS 적용              |
|        |           | 세션 저장소 보호 여부<br>ex) 세션 정보 탈취                   | 상   | 저장소 분리 및 접근 권한 제한           |
|        |           | Access Token 저장소 보호 여부<br>ex) 토큰 정보 탈취         | 상   | Secure Storage 적용           |
|        |           | CA 서버 물리적 보호 여부<br>ex) 루트 인증서 키 탈취             | 치명적 | HSM · 망분리 · 출입 통제           |
|        |           | 백업 매체 반출 통제 여부<br>ex) 백업본 유출                   | 상   | 백업 암호화 및 반출 승인              |
|        | 시설 장애     | 알려진 취약 장치 관리 여부<br>ex) 취약 장비 악용                | 상   | 정기 패치 및 취약점 점검              |
|        |           | 전원 장애 대응 여부<br>ex) 정전으로 서비스 중단                 | 중   | UPS 및 이중 전원 구성              |
|        |           | 재난 대응 여부<br>ex) 화재·침수로 서버 손상                   | 상   | 소화 설비 및 DR 센터 구축            |

## 4 서버 및 네트워크 구성

### 4.1. 서버 구성

#### 4.1.1. 전체 서버 구성도

[그림3] 금융인증서 검증 시퀀스 다이어그램



#### 4.1.2. 서버별 상세

[표 13] 서버별 상세

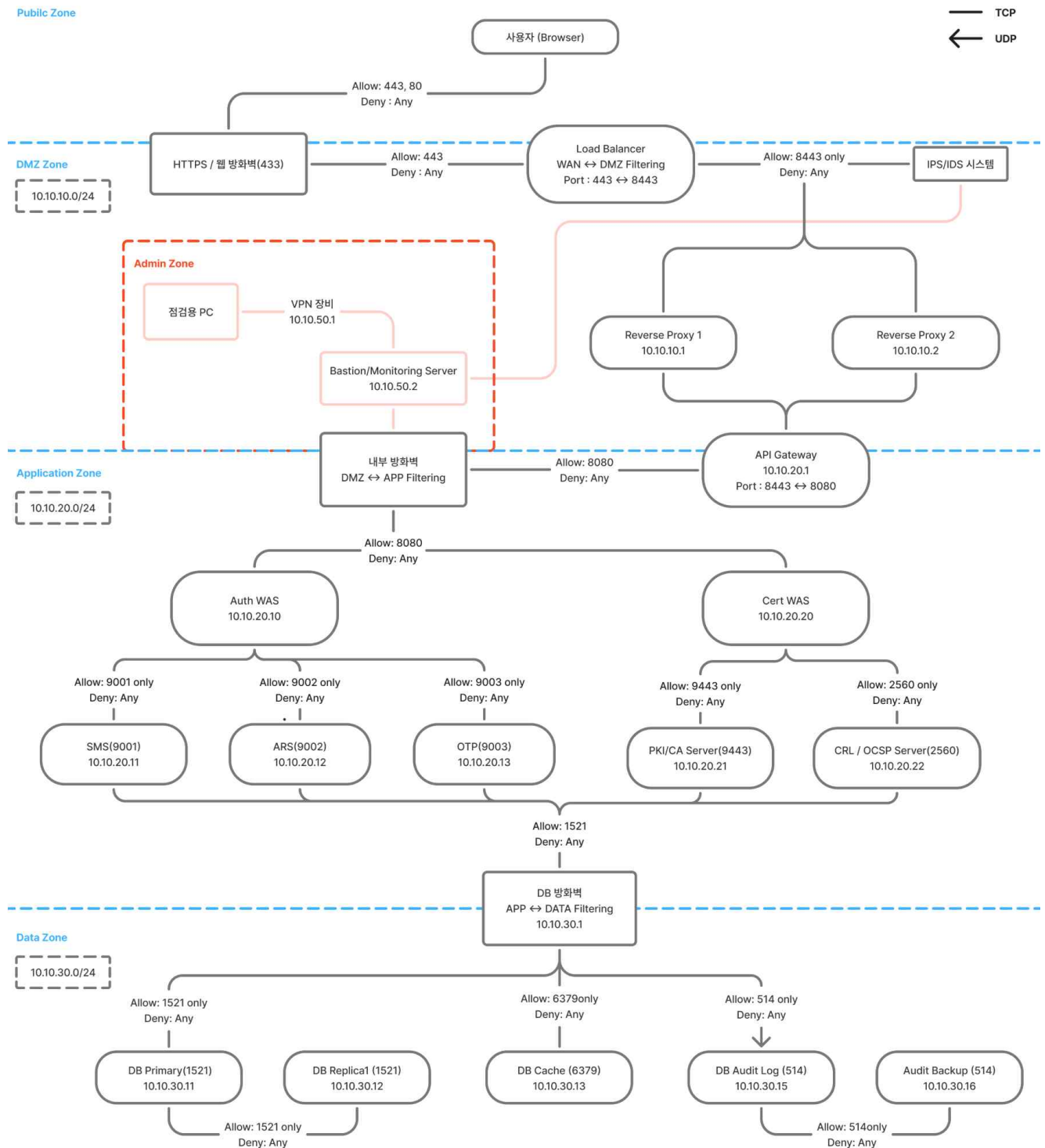
| 서버                                   | 역할                                  | 사양  |     |       | 소프트웨어                                              |                                                   |
|--------------------------------------|-------------------------------------|-----|-----|-------|----------------------------------------------------|---------------------------------------------------|
|                                      |                                     | CPU | RAM | SSD   | OS                                                 |                                                   |
| Load Balancer<br>WAF                 | 외부 사용자 요청 수신 및 트래픽 분산               | 8   | 16  | 256gb | Ubuntu Server 22.04                                | Nginx 1.24+<br>ModSecurity                        |
|                                      | 웹 방화벽(WAF) 기반 악성 공격 필터링             |     |     |       |                                                    |                                                   |
|                                      | SSL/TLS 종단                          |     |     |       |                                                    |                                                   |
| WEB server                           | 내부 WAS의 IP은닉 및 보안강화                 | 4   | 8   | 256gb | Ubuntu Server 22.04                                | Nginx 1.24                                        |
|                                      | 정적 파일(이미지 스크립트) 캐싱 및 처리             |     |     |       |                                                    |                                                   |
| API Gateway                          | 클라이언트 요청 라우팅 및 단일 진입점 역할            | 4   | 16  | 256gb | Ubuntu Server 22.04                                | Spring Cloud Gateway또는 Kong Gateway 3.x           |
|                                      | Api 토큰검증, 트래픽 제한                    |     |     |       |                                                    |                                                   |
| Auth WAS<br>본인인증서버                   | 사용자 로그인, 회원가입 비즈니스 로직 처리            | 8   | 32  | 512gb | Red Hat Enterprise Linux (RHEL) 9 또는 Rocky Linux 9 | OpenJDK 17+<br>Tomcat 10+ Spring Boot 3.x         |
|                                      | 본인인증 연계 로직제어                        |     |     |       |                                                    |                                                   |
| Cert WAS<br>인증서 서버                   | 금융인증서 발급, 재발급, 갱신 로직 처리             | 8   | 32  | 512gb | Red Hat Enterprise Linux (RHEL) 9 또는 Rocky Linux 9 | OpenJDK 17+<br>Tomcat 10+ Spring Boot 3.x         |
|                                      | 전자서명 검증 및 인증서 상태확인 요청 제어            |     |     |       |                                                    |                                                   |
| Moniter/Bastion Server<br>모니터/배스천 서버 | 내부 인프라(WAS/DB등) 관리를 위한 보안 점프 호스트 역할 | 8   | 32  | 512gb | 512gb                                              | Prometheus 2.45 +<br>Grafana 10.0                 |
|                                      | 시스템 자원 상태, 실시간 성능 모니터링 및 로깅 수집      | 8   | 16  | 1TB   | ROCKY LINUX                                        | OpenSSH 9.x +<br>Prometheus 2.x +<br>Grafana 10.0 |

| 서버              | 역할                              | 사양  |     |       | 소프트웨어                                              |                                                         |
|-----------------|---------------------------------|-----|-----|-------|----------------------------------------------------|---------------------------------------------------------|
|                 |                                 | CPU | RAM | SSD   | OS                                                 |                                                         |
| SMS/ARS Server  | 통신사 연동 모듈을 통한 인증 번호 발송          | 4   | 8   | 512gb | Ubuntu Server 22.04                                | RabbitMQ 3.12(또는 Apache Kafka)+ 통신사 연동 전용 Agent         |
|                 | 알림톡 및 대량 문자 발송 큐 (Queue) 관리     |     |     |       |                                                    |                                                         |
| OTP Server      | 시간동기화(TOTP) 기반 OTP값 검증 알고리즘 수행  | 4   | 16  | 512gb | Red Hat Enterprise Linux (RHEL) 9 또는 Rocky Linux 9 | 가상화 OTP 검증 엔진 (또는 TOTP 오픈소스 모듈)                         |
|                 | OTP기기 등록 및 상태 관리                |     |     |       |                                                    |                                                         |
| PKI/CA Server   | 자체 사설 인증서(공인인증 체계 호환) 키 생성 및 관리 | 8   | 16  | 512gb | Red Hat Enterprise Linux (RHEL) 9 또는 Rocky Linux 9 | OpenSSL기반 사설 CA 엔진 (또는 상용 PKI 솔루션)                      |
|                 | 인증서 발급 검증 및 암호화 알고리즘 처리         |     |     |       |                                                    |                                                         |
| CRL/OCSP Server | 실시간 인증서 폐기 목록(CRL) 관리           | 4   | 16  | 512gb | Red Hat Enterprise Linux (RHEL) 9 또는 Rocky Linux 9 | Apache HTTPD 2.4 (OCSP 모듈 활성화)또는 OpenSSL OCSP Responder |
|                 | OCSP프로토콜을 이용한 실시간 인증서 유효성 검증    |     |     |       |                                                    |                                                         |
| User DB         | 고객 기본 정보 등 핵심 금융 데이터 저장         | 16  | 64  | 2 TB  | Rocky Linux 9                                      | PostgreSQL 15 (또는 Oracle 19c)                           |
|                 | 트랙잭션(ACID)보장 및 실시간 데이터 동기화      |     |     |       |                                                    |                                                         |
| Certificate DB  | 발급된 금융 인증서 및 공개키 데이터 저장         | 8   | 32  | 2tb   | Rocky Linux 9                                      | PostgreSQL 15                                           |
| Audit Log DB    | 금융 보안 규정을 위한 로그인 기록, 거래 이력 저장   | 16  | 32  | 4TB   | Rocky Linux 9                                      | Elasticsearch 8.x 또는 PostgreSQL 15                      |
|                 | 대용량 로그 데이터의 안정적인 적재 및 백업        |     |     |       |                                                    |                                                         |
| Cache Server    | 세션 정보 저장 및 공유                   | 8   | 32  | 1TB   | Ubuntu Server 22.04 LTS                            | Redis 7.x                                               |
|                 | 자주 조회되는 데이터 캐싱으로 DB부하 감소        |     |     |       |                                                    |                                                         |

## 4.2. 네트워크 구성

### 4.2.1. 네트워크 다이어그램

[그림4] 네트워크 다이어그램



#### 4.2.2. 네트워크 구역별 설명

[표 14] 네트워크 구역

| 구역               | IP 대역         | 용도                                        | 배치 서버                                                                   |
|------------------|---------------|-------------------------------------------|-------------------------------------------------------------------------|
| public zone      | 공인 IP         | 웹서비스 이용자<br>(외부 브라우저)가 접근하는<br>공용 인터넷 구간  | 사용자 브라우저                                                                |
|                  |               | HTTPS (443) 통신을 통해<br>DMZ의 로드밸런서로 연결      |                                                                         |
| DMZ              | 10.10.10.0/24 | 외부 인터넷망과 내부망<br>사이의 완충구역                  | Load Balancer,<br>Web Server 1,2                                        |
|                  |               | 내부 WAS인프라의 IP유출을<br>차단하는 보안 프록시 구간        |                                                                         |
| Application zone | 10.10.20.0/24 | 내부 비즈니스 로직<br>(인증,금융처리) 및<br>대외 연계 트래픽 처리 | Auth WAS, Cert WAS ,<br>SMS/ARS ,OTP Server,<br>PKI/CA, CRL/OCSP server |
|                  |               | 망 방화벽을 거쳐 인가된 요청만<br>수신하는 구간              |                                                                         |
| Data Zone        | 10.10.30.0/24 | 은행 핵심 자산데이터, 인증서, 로<br>그가 적재되는 최상위 보안 구간  | User DB, Certificate DB,<br>Audit Log DB, Backup DB                     |

#### 4.2.3. 네트워크 주요 보안 장비

[표 15] 네트워크 보안 장비

| 구분                      | 주요 역할                                               | 작동 방식                                                                      |
|-------------------------|-----------------------------------------------------|----------------------------------------------------------------------------|
| 내부망 방화벽                 | 네트워크 구역 간 불필요한<br>모든 통신을 원천 차단하는<br>통제관             | 패스워드나 데이터 내용은 보지 않고, 오직 출발지/목적지<br>IP 주소와 포트 번호만 확인하여 허용/차단함               |
| 웹 방화벽                   | HTTP/HTTPS를 노린<br>정밀 저격 공격방어                        | 사용자가 입력창이나 주소창에 넣어서 보내는 HTTP 요청<br>데이터 내용을 뜯어보고 해킹 코드가 있으면 차단함             |
| DB방화벽                   | 데이터베이스의 무단 접근<br>및 무단 쿼리 차단                         | WAS가 DB에 날리는 SQL 명령어 구문을 실시간으로<br>분석하여, 권한이 없거나 대량 조회를 시도하면 세션을<br>강제 종료함  |
| IPS/IDS<br>(침입방지/탐지시스템) | 악성코드, 시스템 취약점<br>유포패킷, 디도스 등 네트워크<br>전반의 유해 트래픽 차단  | 회선을 통과하는 모든 패킷의 알맹이 전체를 악성코드나<br>디도스 등의 해킹 패턴 데이터베이스와 실시간 대조하여<br>차단함      |
| 보안 VPN 장비               | 공용 인터넷망을 안전한 사내<br>전용선처럼 쓸 수 있게 해주는<br>암호화 가상 터널 생성 | 외부 PC와 내부망 사이에 암호화된 가상 터널을 뚫어<br>데이터를 캡슐화해 주고,<br>강력한 다요소 인증(MFA)을 거쳐 통과시킴 |

## 5 보안정책

### 5.1. 접근 제어 정책

#### 5.1.1. 방화벽 규칙

[표 16] Public Zone → DMZ Zone 규칙

| 출발지          | 목적지 포트        | 프로토콜 및 포트 | 허용/차단      | 사유              |
|--------------|---------------|-----------|------------|-----------------|
| 외부망(Browser) | WAF (HTTPS)   | TCP 443   | 허용 (Allow) | 웹서비스 대만 서비스 개방  |
| 외부망(Browser) | WAF (HTTPS)   | TCP 80    | 허용 (Allow) | redirect용으로만 사용 |
| WAF (HTTPS)  | load balancer | TCP 443   | 허용 (Allow) | DMZ Zone 진입 요청  |
| 외부망          | DMZ Zone      | 모든 포트     | 차단 (Deny)  | 위 규칙외 접근 차단     |

[표 17] DMZ Zone → APP Zone 규칙

| 출발지           | 목적지 포트      | 프로토콜 및 포트 | 허용/차단      | 사유                     |
|---------------|-------------|-----------|------------|------------------------|
| load balancer | web1,2      | TCP 8443  | 허용 (Allow) | DMZ Zone 진입            |
| web1,2        | API Gateway | TCP 8443  | 허용 (Allow) | Application Zone 진입 요청 |
| DMZ Zone      | App Zone    | 모든 포트     | 차단 (Deny)  | 허용된 WAS포트 외 내부 진입 원천차단 |

[표 18] Admin Zone 규칙

| 출발지            | 목적지 포트            | 프로토콜 및 포트      | 허용/차단  | 사유             |
|----------------|-------------------|----------------|--------|----------------|
| Admin PC       | VPN Gateway       | TCP 443 / 1194 | 허용     | 외부와 차단         |
| VPN Gateway    | Bastion Server    | TCP 22         | 허용     | 관리자 인증 후 진입    |
| Bastion Server | Monitoring Server | TCP 443        | 허용     | 보안 모니터링        |
| Bastion Server | WAF / LB / WAS    | TCP 22         | 제한적 허용 | 관리자 유지보수       |
| Bastion Server | DB Server         | TCP 22         | 제한적 허용 | DB 관리          |
| Admin Zone     | Internal Zone     | Any            | 차단     | Bastion 경유만 허용 |

[표 19] APP Zone 내 규칙

| 출발지         | 목적지 포트          | 프로토콜 및 포트        | 허용/차단      | 사유                     |
|-------------|-----------------|------------------|------------|------------------------|
| API Gateway | Auth WAS        | TCP 8080         | 허용 (Allow) | 인증요청                   |
| API Gateway | Cert WAS        | TCP 8080         | 허용 (Allow) | 인증서 검증 요청              |
| Auth WAS    | SMS Server      | TCP 9001         | 허용 (Allow) | 사용자 인증 시 SMS 발송 연동     |
| Auth WAS    | ARS Server      | TCP 9002         | 허용 (Allow) | 사용자 인증 시 ARS 발송 연동     |
| Auth WAS    | OTP Server      | TCP 9003         | 허용 (Allow) | 사용자 인증 시 OTP 검증        |
| Cert WAS    | PKI/CA Server   | TCP 9443         | 허용 (Allow) | 전자서명 및 인증서 체인 검증       |
| Cert WAS    | CRL/OCSP Server | TCP 2560         | 허용 (Allow) | 인증서 유효성 검증 연동          |
| App Zone    | Data Zone       | TCP 1521(Oracle) | 허용 (Allow) | Data Zone 진입 요청        |
| App Zone    | Data Zone       | 모든 포트            | 차단 (Deny)  | 허용된 WAS포트 외 내부 진입 원천차단 |

[표 20] APP Zone → Data Zone 규칙

| 출발지                 | 목적지 포트           | 프로토콜 및 포트 | 허용/차단      | 사유                    |
|---------------------|------------------|-----------|------------|-----------------------|
| App Zone            | DB Primary       | TCP 1521  | 허용 (Allow) | 공개키 저장                |
| DB Primary          | DB Replication 1 | TCP 1521  | 허용 (Allow) | Primary 백업            |
| App Zone            | Cache Server     | TCP 6379  | 허용 (Allow) | 세션 및 캐시 데이터 접근        |
| App Zone            | DB Audit Log     | UDP 514   | 허용 (Allow) | 보안 및 행위 로그 전송         |
| DB Audit Log        | Audit Backup     | TCP 514   | 허용 (Allow) | Audit Log 백업          |
| Application Zone 전체 | Data Zone 전체     | Any       | 차단 (Deny)  | 허용된 DB/로그 포트 외 무조건 차단 |

### 5.1.2. IP 접근 제어

[표 21] 화이트리스트 (허용 목록)

| 구분                          | 수치                            |
|-----------------------------|-------------------------------|
| 외부 사용자 IP                   | 웹 방화벽 443 포트만 접속 허용           |
| WEB 1,2 ip (10.10.10.1~2)   | API Gateway 웹트래픽 진입 허용        |
| API Gateway IP (10.10.20.1) | 하위 WAS로의 API호출 허용             |
| 인증서버 대역 (10.10.20.0/24)     | DB Server의 서비스 포트(3306) 진입 허용 |
| 점검용 PC(고정 ip 할당)            | 점검용 PC 서버 관리 포트 접속 허용         |

[표 22] 블랙리스트 (차단 목록)

| 구분                          | 수치                                      |
|-----------------------------|-----------------------------------------|
| 비인가 zone 직접 접근 시도 IP        | Data Zone으로 직접 라우팅 시도 시 즉시 차단           |
| 해외/특정 국가 IP 접근              | 허용된 서비스 국가 외 대역 접근 시 영구 차단              |
| 인증(SMS/ARS/OTP) 5회 이상 실패 IP | 해당 IP 및 관련 인증 세션 차단<br>(관리자 권한으로 복구 가능) |
| 내부 방화벽 룰 위반 및 기타 의심 행위      | IDS/IPS 연동을 통한 실시간 수동/자동 차단             |
| 점검용 PC 비밀번호 5회 실패 시         | 점검용 PC 접근 차단 (백업 USB 복구)                |
| 화이트 리스트를 제외한 모든 IP          | 접근 차단                                   |

## 5.2. 사용자 인증 및 권한 정책

### 5.2.1. 개인정보 암호화 정책

[표 23] 개인정보 암호화 정책

| 구분          | 항목                  | 수치                                                         |
|-------------|---------------------|------------------------------------------------------------|
| 최초 인증       | OAuth 2.0 기반 JWT 도입 | ID/PW 검증 후 Access/Refresh 토큰<br>이원화 발급                     |
| 세션 유효성      | Access Token 유효기간   | 10분 (만료 시 Refresh Token으로 자동 갱신)                           |
| 추가 인증 (MFA) | 2차 인증 격상 조건         | 금융인증서 발급/검증(Cert WAS), 개인정보<br>및 주요 설정 변경 시                |
| MFA 수단      | 다중 인증 채널 운영         | SMS(10.10.20.11), ARS(10.10.20.12),<br>OTP(10.10.20.13) 연동 |

### 5.2.2. 사용자 식별 정책

[표 24] 사용자 식별 정책

| 계정 종류    | 권한                                    | 용도                                           |
|----------|---------------------------------------|----------------------------------------------|
| 실명·본인 확인 | 사용자 신원 정보<br>(이름, 계좌, 예금주 정보)         | 가입 계좌 정보와 예금주 실명 정보의 일치 여부를<br>검증하여 본인 여부 확인 |
| 단말 소유 검증 | 사용자 인증 단말 (휴대폰,<br>ARS 수신 번호, OTP 기기) | SMS-ARS-OTP 기반 추가 인증을 수행하여 본인 소유<br>단말 여부 검증 |

### 5.2.3. 자격 증명 및 PIN 통제 정책

[표 25] 자격 증명 및 PIN 통제 정책

| 계정 종류    | 권한                                 | 용도                                                     |
|----------|------------------------------------|--------------------------------------------------------|
| 자격 증명 검증 | 사용자 인증 상태<br>(계정, 인증서, Fail Count) | 인증서 발급 및 검증 전 사용자 계정 상태와 인증 실패<br>횟수를 조회하여 인증 가능 여부 검증 |
| PIN 생성   | 사용자 PIN                            | 6자리 숫자 PIN 사용, 연속·반복·개인정보 기반 조합 금지                     |
| PIN 저장   | PIN 저장 데이터                         | PIN 단방향 해시 저장 및 평문 저장 금지                               |

### 5.2.4. 인증 실행 및 시도 제한 정책

[표 26] 인증 실행 및 시도 제한 정책

| 계정 종류      | 권한                    | 용도                                                          |
|------------|-----------------------|-------------------------------------------------------------|
| 계정 잠금      | 인증 실패 횟수 (Fail Count) | 인증 실패 5회 누적 시 10분간 계정을 잠금하며, 10회<br>이상 실패 시 관리자 해제 후 재인증 필요 |
| 속도 제한      | 인증 요청 빈도 (IP·계정)      | 동일 IP 및 계정 기준으로 일정 시간 내 인증 요청<br>횟수를 제한하여 무차별 대입 공격 방지      |
| 에러 메시지 마스킹 | 인증 실패 응답 정보           | 계정 존재 여부, PIN 불일치 등 상세 실패 원인을<br>노출하지 않고 일반화된 오류 메시지 제공     |
| 인증 유효시간    | 인증 코드 (SMS-ARS-OTP)   | SMS-ARS-OTP 인증번호는 제한된 시간 동안만 유효하며<br>만료 시 재발급 필요            |

### 5.2.5. 다요소 인증 정책

[표 27] 다요소 인증 정책

| 계정 종류      | 권한             | 용도                                    |
|------------|----------------|---------------------------------------|
| MFA 필수화    | 인증서 발급·검증 프로세스 | 인증서 발급·재발급·검증 시 독립된 2개 이상 인증 수단 조합 필수 |
| 인가 및 접근제어  | 단계별 권한 상승      | 재발급·PIN 변경·폐기 시 MFA 재인증               |
| OTP 재사용 방지 | OTP Token      | 1회 사용 후 즉시 폐기                         |
| 인증 유효시간 관리 | 인증 코드          | 1~3분 내 입력, 만료 시 재발급                   |

### 5.2.6. 상황 기반 통제 및 세션 정책

[표 28] 상황 기반 통제 및 세션 정책

| 구분           | 항목                                                                       |
|--------------|--------------------------------------------------------------------------|
| 지리적 이상 이동 탐지 | 단시간 내 물리적으로 불가능한 위치 변화 감지 시 Risk-Based Authentication(RBA) 적용 및 추가 인증 수행 |
| 세션 타임아웃 정책   | 일정 시간(예: 10~15분) 비활성 상태 지속 시 세션 자동 만료 후 재인증 요구                           |
| 동시 접속 통제 정책  | 동일 계정의 다중 브라우저·다중 기기 동시 세션 생성 제한 또는 기존 세션 종료                             |

### 5.2.7. 보안 운영 및 인증서 관리 정책

[표 29] 보안 운영 및 인증서 관리 정책

| 계정 종류      | 권한             | 용도                                           |
|------------|----------------|----------------------------------------------|
| 감사 로그 관리   | 인증 이력 및 사용자 행위 | 인증서 발급·검증 성공/실패 이력을 Audit Log에 기록하고 일정 기간 보관 |
| 이상 탐지      | 비정상 인증 시도      | 무차별 대입, 비정상 접근 패턴 탐지를 위해 SIEM 연동             |
| 인증서 재발급 관리 | 인증서 재발급 요청     | 재발급 시 기존 인증서는 즉시 폐기하고 본인 재인증 수행              |
| PIN 변경 관리  | PIN 변경 요청      | PIN 변경 시 기존 PIN 검증 및 MFA 재인증 필수              |
| 인증서 폐기 관리  | 폐기/만료 인증서      | 폐기된 인증서는 CRL/OCSP에 즉시 반영하여 검증 차단             |
| 인증서 만료 관리  | 만료 예정 인증서      | 만료 30일 전 사용자에게 사전 알림 및 갱신 안내                 |

### 5.3. 관리자 계정 정책

#### 5.3.1. SSH 관리자 계정 보안 정책

[표 30] SSH 관리자 계정 보안 정책

| 구분        | 통제 대상        | 정책 내용                                     |
|-----------|--------------|-------------------------------------------|
| 관리자 계정 식별 | SSH 접속 계정    | 공용 계정(root, admin) 사용 금지,<br>개인별 계정 발급    |
| 인증 방식     | SSH 로그인      | 비밀번호 로그인 비활성화,<br>SSH Key + MFA 필수        |
| 접근 경로 제한  | 서버 접근 경로     | 직접 SSH 접속 금지,<br>Bastion Server 경유 접속만 허용 |
| IP 접근 제한  | 허용 네트워크      | 운영망/VPN 허용 IP만 SSH 접근 가능                  |
| 권한 상승 통제  | sudo/root 권한 | 필요 시 sudo 사용, root 직접 로그인 차단              |
| 세션 관리     | SSH 세션       | 일정 시간 비활성 시 자동 세션 종료                      |
| 명령 감사     | 관리자 작업 내역    | 모든 SSH 명령어 및<br>접속 이력 Audit Log 저장        |
| 이상 탐지     | 비정상 접속       | 야간 접속·해외 IP·반복 실패 탐지 시<br>SIEM 경보         |

#### 5.3.2. 관리자 페이지 접근 정책

[표 31] 관리자 페이지(백오피스) 관리자 계정 보안 정책

| 구분        | 통제 대상    | 정책 내용                                |
|-----------|----------|--------------------------------------|
| 관리자 인증    | 백오피스 로그인 | ID/PW + MFA 기반 다중 인증 필수              |
| 접근 권한 분리  | 운영자 계정   | 업무별 RBAC 적용 (고객조회 / 발급승인 /<br>감사 분리) |
| 민감 기능 재인증 | 중요 기능    | 인증서 발급 승인·폐기·PIN<br>초기화 시 재인증        |
| 세션 보호     | 로그인 세션   | Secure Cookie, HttpOnly, SameSite 적용 |
| 동시 접속 제한  | 관리자 세션   | 동일 계정 다중 로그인 차단                      |
| 화면 접근 통제  | 민감 페이지   | 관리자 메뉴별 세부 권한 검증                     |
| 행위 감사     | 관리자 작업   | 조회·수정·삭제 행위 Audit Log 저장             |
| 계정 잠금     | 로그인 실패   | 5회 실패 시 잠금, 관리자 승인 후 해제              |

5.3.3. DB 접근 권한

[표 32] DB접근 정책

| 계정 종류     | 권한        | 용도                               |
|-----------|-----------|----------------------------------|
| 계정 분리     | DB 계정     | 관리자·운영자·애플리케이션 계정 분리             |
| 최소 권한     | SQL 권한    | 업무상 필요한 SELECT/INSERT/UPDATE만 허용 |
| 직접 접근 통제  | DB 서버     | 일반 운영자의 DB 직접 접속 금지              |
| 민감정보 보호   | 개인정보 컬럼   | 주민번호·계좌번호·인증서 키 암호화 저장           |
| 쿼리 감사     | DB 작업     | SELECT 포함 중요 SQL Audit Log 저장    |
| 변경 승인     | 스키마 변경    | DDL 작업은 승인 절차 후 수행               |
| 백업 데이터 보호 | DB Backup | 백업 파일 암호화 및 반출 승인                |
| 이상 행위 탐지  | DB 접근 패턴  | 대량 조회·비정상 쿼리 탐지 및 경보             |

5.4. 데이터 보호 정책

5.4.1. HTTPS 적용

[표 33] HTTPS 적용 정책

| 구분          | 수치                                                         |
|-------------|------------------------------------------------------------|
| SSL/TLS 인증서 | 알고리즘 ECDSA 256비트 또는 RSA 2048비트 이상 공인인증서 적용                 |
|             | HTTP(80 포트) 접속 시 HTTPS(443 포트)로 301 Permanent Redirect 강제  |
|             | 대고객 채널 및 외부 연계 채널 전 구간 TLS 1.3 최신 보안 프로토콜 적용               |
|             | 웹 서버-API Gateway-WAS 전 구간 내부 사설 mTLS(상호 인증) 암호화 구축         |
| 적용 효과       | 금융 데이터 전송 구간 스니핑 차단 및 고유 무결성 보장                            |
|             | SSL Strip 및 중간자 공격(MITM)을 통한 세션/인증 토큰 탈취 원천 방지             |
|             | 전자금융감독규정 및 개인정보보호법 전송 구간 암호화 컴플라이언스 충족                     |
| 적용 후 점검 사항  | 브라우저 주소창 자물쇠 표시 및 SSL/TLS 인증서 만료일 및 체인 신뢰성 상시 모니터링         |
|             | TLS 1.0, 1.1 및 취약한 암호화 알고리즘(DES, RC4) 비활성화 여부 점검           |
|             | 외부 서드파티 리소스(API, 이미지) 호출 시 Mixed Content(HTTP) 발생 여부 전수 조사 |
|             | Qualys SSL Labs 및 금융보안원 검사 기준 최상위 등급(A+ 이상) 획득 여부 검증       |

### 5.4.2. 개인정보 암호화

[표 34] 개인정보 암호화 정책

| 암호화 대상 | 알고리즘            | 비고             |
|--------|-----------------|----------------|
| 비밀번호   | Argon2 / PBKDF2 | 단방향 해시, 복호화 불가 |
| 이름     | AES-256         | 개인정보 보호        |
| 주민등록번호 | AES-256         | 고위험 민감정보       |
| 주소     | AES-256         | 개인정보 보호        |
| 계좌번호   | AES-256         | 금융정보 보호        |
| 전화번호   | AES-256         | 개인정보 보호        |

### 5.4.3. 개인키 관리 정책

[표 35] 개인키 관리 정책

| 항목   | 정책                 |
|------|--------------------|
| 키 저장 | KMS/HSM 분리 보관      |
| 키 교체 | 6~12개월 주기 Rotation |
| 키 접근 | 관리자 승인 기반          |
| 키 백업 | 암호화 후 오프라인 보관      |

### 5.4.4. DB 암호화

[표 36] DB 암호화 정책

| 구분                                | 암호화 대상                     | 정책/적용 내용                                         | 적용 방식         |
|-----------------------------------|----------------------------|--------------------------------------------------|---------------|
| 응용프로그램(API) 암호화                   | 로그인/계좌 비밀번호                | WAS(Application Server)에서 DB 전송 전 선제적으로 암호화 후 저장 | API 방식        |
| DB Plugin 암호화                     | 주민등록번호, 계좌번호, 이름, 주소, 전화번호 | DB 서버에 암호화 플러그인을 탑재하여 컬럼 단위 실시간 암·복호화 수행         | DB Plug-in 방식 |
| TDE (Transparent Data Encryption) | 거래 이력, Audit Log, DB 파일 전체 | DB 엔진 자체 기능으로 데이터 파일·테이블 스페이스·백업 파일 전체 암호화       | TDE 방식        |
| 키 관리                              | 모든 암호화 키                   | 마스터 키는 DB와 분리된 키 관리 시스템 (KMS/HSM)에 별도 보관         | KMS / HSM     |
| 접근 통제                             | 암호화 데이터 접근 계정              | 관리자·운영자·애플리케이션 계정 권한 분리 및 최소 권한 적용               | 권한 분리         |

5.5. 암호화 방식 선정 기준

[표 37] 암호화 방식 선정 기준

| 방식          | 장점             | 적용 이유                     |
|-------------|----------------|---------------------------|
| API 암호화     | DB 도달 전 암호화 가능 | 비밀번호처럼 복호화가 불필요한 민감정보 보호  |
| Plug-in 암호화 | 컬럼 단위 제어 가능    | 조회·검색이 필요한 개인정보 처리에 적합    |
| TDE         | 운영 부담 적음       | 파일 탈취, 백업 유출 등 저장매체 공격 방어 |

## 5.6. 보안 관리 정책

### 5.6.1. 보안 업데이트

[표 38] 보안 업데이트 정책

| 구분                    | 정책                                    |
|-----------------------|---------------------------------------|
| 운영체제 업데이트             | 매월 둘째·넷째 주 일요일 00:00~04:00 정기 업데이트 수행 |
| 긴급 보안 패치              | Critical 취약점 발생 시 발표 후 24시간 이내 적용     |
| WEB Server / WAS 업데이트 | 블루-그린 배포 방식으로 무중단 순차 업데이트             |
| DB 업데이트               | Replica 서버 우선 업데이트 후 Primary와 동기화 수행  |

### 5.6.2. 블루 그린 배포 방식

[표 39] 블루 그린 배포 방식 정책

| 구분    | 정책                                      |
|-------|-----------------------------------------|
| 방식    | 운영 환경(Blue)과 동일한 신규 환경(Green) 사전 구성     |
| 전환    | 검증 완료 후 Load Balancer에서 트래픽을 Green으로 전환 |
| 장애 대응 | 문제 발생 시 Blue 환경으로 즉시 Rollback           |

### 5.6.3. 백업 정책

[표 40] 백업 정책

| 구분     | 수치                    |
|--------|-----------------------|
| 백업 대상  | 데이터베이스 전체             |
| 주요 데이터 | 고객 정보 및 인증서 DB        |
| 로그 데이터 | Audit Log 및 시스템 운영 로그 |
| 저장 방식  | 백업 파일 암호화 후 별도 저장소 보관 |

### 5.6.4. 백업 주기

[표 41] 백업 주기

| 구분    | 정책                                                                                 |
|-------|------------------------------------------------------------------------------------|
| 백업 주기 | 실시간 증분 백업 + 매일 00:00 전체 백업                                                         |
| 보관 기간 | 최소 7일 이상 보관 (운영 정책에 따라 장기 보관 가능)<br>운영 백업 : 7~30일 / 감사 로그 : 1~5년 / DR/Archive : 수년 |
| 백업 위치 | DB 전용 백업 서버 및 DR 저장소                                                               |
| 수행 방식 | 자동화 백업 솔루션 기반                                                                      |

### 5.6.5. 백업 확인

[표 42] 백업 확인 체크리스트

| 구분     | 정책                         |
|--------|----------------------------|
| 일일 점검  | 매일 오전 08:00 백업 솔루션 대시보드 확인 |
| 무결성 검증 | 백업 파일 용량 및 체크섬 전일 데이터와 비교  |
| 복구 검증  | 정기 복구 테스트 수행               |
| 장애 대응  | 백업 실패 시 관리자 즉시 알림 및 재백업 수행 |

## 5.7. 로그 기록 및 보관 정책

### 5.7.1. 로그 기록 대상

[표 43] 로그 기록 대상

| 구분         | 수치                         |
|------------|----------------------------|
| 로그인/로그아웃   | 사용자 ID IP 접속 시간            |
| 주요 기능사용 로그 | ARS 인증, SMS인증, OTP인증, 전자서명 |
| 인증 거부 로그   | 인증 실패 로그                   |
| 에러 로그      | 시스템 오류, 애플리케이션 에러          |
| 서버접속 로그    | 관리자 PC 접속 로그               |

### 5.7.2. 로그 보관 기간

[표 44] 로그 보관기관

| 구분            | 수치                   |
|---------------|----------------------|
| 전자금융거래 로그     | 보관기간 5년(금융거래법)       |
| 개인정보취급자 접근 로그 | 보관기간 1년(개인정보보호법)     |
| 인프라 및 보안장비 로그 | 보관기간 6개월 이상(ISMS-P)  |
| 웹 로그          | 보관기간 3개월 이상(통신비밀보호법) |

### 5.7.3. 로그 점검

[표 45] 로그 점검 체크리스트

| 구분        | 수치                                 |
|-----------|------------------------------------|
| 매일 오전, 오후 | 확인한 로그 이후의 개인정보 취급자 및 관리자 접근 로그 점검 |
| 매주 월요일    | 월 ~ 일요일까지의 로그 기준으로 보고서 작성          |

## 5.7.4. 정기 점검

[표 46] 정기 점검 체크리스트

| 구분    | 수치                                                                 |
|-------|--------------------------------------------------------------------|
| 일일 점검 | 운영 상태 및 비정상 행위 상시 모니터링                                             |
|       | 데이터: 근무 시간 외(야간/주말) 개인정보(주민번호, 계좌 등)의 1회당 100건 이상 대량 조회·추출 이력 확인   |
|       | 로그: 중앙 로그 서버(Syslog)로의 데이터 적재 상태(0 Byte 누락 여부) 점검                  |
|       | 계정: 인프라 최고 관리자 계정(root, sa)의 접속 IP 대조 및 비정상 명령어 실행 여부 검증           |
|       | 네트워크: 방화벽, IPS 등 보안 장비의 실시간 침입 탐지/차단 로그 및 유효성 확인                   |
| 주간 점검 | 인프라 시스템 및 보안 장비 정밀 분석                                              |
|       | 계정: 내부 직원 및 협력업체 계정 중 패스워드 5회 연속 오류로 인한 잠금(Lock) 발생 현황 추적          |
|       | 성능: DB 서버(pc10, pc11) 및 핵심 WAS의 CPU/메모리 임계치(80% 이상) 초과 이벤트 분석      |
|       | 네트워크: 특정 외부 IP로부터의 지속적인 포트 스캐닝(Port Scanning) 및 디도스(DDoS) 의심 징후 분석 |
|       | 백업: 주간 전체 백업(Full Backup) 수행 결과 검증 및 무결성(Hash 값 일치 여부) 일일 대조 결과 취합 |
| 월간점검  | KMS 키 관리 및 사용자 권한 변경 전수 감사                                         |
|       | 암호화: KMS/HSM 장비의 암호화 키 생성/변경 로그와 사전 마스터 결재 문서의 1:1 대조·검증           |
|       | 권한: 사내 인사 이동·퇴사자 정보를 기반으로 미사용 계정의 권한 회수 및 맵핑 상태 100% 전수 감사         |
|       | 소스: 운영 서버 배포 소스코드 내 암호화 키 하드코딩 여부 정적 분석(SAST) 결과 검토                |
|       | 훈련: 재해복구(DR) 및 백업 데이터를 활용한 Sandbox 환경 내 가상 복구 시뮬레이션 모의 훈련 수행       |

## 6 부록

### 6.1. 참고 자료

#### 6.1.1. 보안 기준

[표 47] 참고자료

| 구분                  | 수치                                                                          |
|---------------------|-----------------------------------------------------------------------------|
| OWASP Top 10 : 2025 | <a href="https://owasp.org/Top10/2025/">https://owasp[.]org/Top10/2025/</a> |
| CWE                 | <a href="https://cwe.mitre.org/">https://cwe[.]mitre[.]org/</a>             |
| 한국인터넷진흥원            | <a href="https://www.kisa.or.kr">https://www[.]kisa.or[.]kr</a>             |
| 개인정보보호포탈            | <a href="https://www.privacy.go.kr">https://www[.]privacy.go[.]kr</a>       |
| 개인정보보호위원회           | <a href="https://www.pipc.go.kr">https://www[.]pipc.go[.]kr</a>             |

#### 6.1.2. 용어 설명

[표 48] 용어표

| 용어                | 설명                                                              |
|-------------------|-----------------------------------------------------------------|
| User              | 시스템을 사용하는 사용자 또는 서비스 이용 주체                                      |
| Web Service       | 네트워크 상에서 서로 다른 시스템 간 상호작용을 위한 소프트웨어 서비스                         |
| Auth WAS          | 사용자 인증(Authentication) 및 인가(Authorization) 처리를 담당하는 웹 애플리케이션 서버 |
| Cert WAS          | 인증서 생성·발급·검증 처리를 담당하는 웹 애플리케이션 서버                               |
| SMS/ARS Server    | SMS 또는 ARS 기반 인증 요청 및 알림 전송을 담당하는 서버                            |
| PKI / CA Server   | 디지털 인증서를 발급·관리하며 전자서명을 수행하는 인증기관 서버                             |
| CRL / OCSP Server | 인증서 폐기 여부 및 유효성을 검증하는 서버                                        |
| User DB           | 사용자 계정 및 개인정보를 저장하는 데이터베이스                                      |
| Certificate DB    | 인증서 정보(발급, 폐기, 만료 등)를 저장하는 데이터베이스                               |
| Audit Log DB      | 감사 로그를 저장하는 데이터베이스                                              |
| Audit Log         | 누가 언제 어떤 작업을 수행했는지 기록한 감사 로그                                    |
| HTTPS             | HTTP 통신에 TLS 암호화를 적용한 보안 프로토콜                                   |

|                       |                                              |
|-----------------------|----------------------------------------------|
| API Gateway           | 클라이언트 요청을 받아 인증·권한 검사 후 내부 서비스로 라우팅하는 단일 진입점 |
| Presentation Layer    | 데이터 표현 형식 변환 및 인코딩 처리를 담당하는 계층               |
| Business Layer        | 비즈니스 규칙과 핵심 로직을 처리하는 계층                      |
| JPA                   | Java ORM 기술 표준 API                           |
| Public Zone           | 외부 공개 네트워크 영역                                |
| DMZ Zone              | 외부와 내부망 사이에 위치하는 격리 보안 구역                    |
| Cache                 | 자주 사용하는 데이터를 임시 저장하는 메모리 영역                  |
| Cache Server          | 캐시 데이터를 관리하는 전용 서버                           |
| SQL Injection         | 악성 SQL 구문 삽입을 통한 DB 공격                       |
| XSS                   | 악성 스크립트를 삽입해 사용자 브라우저에서 실행시키는 공격             |
| Bot 공격                | 자동화 프로그램을 이용한 대량 요청·공격                       |
| 인증 토큰 검증              | 토큰의 위변조, 권한, 만료 여부를 검증하는 과정                  |
| Routing               | 네트워크 패킷 또는 요청의 경로를 결정하는 과정                   |
| Rate Limiting         | 단위 시간당 요청 횟수를 제한하는 정책                        |
| Logging               | 시스템 이벤트 및 상태를 기록하는 행위                        |
| Database (DB)         | 데이터를 저장·관리하는 논리적 저장소                         |
| Cluster               | 여러 서버를 묶어 고가용성 및 확장성을 제공하는 구조                |
| Load Balancer         | 서버 간 트래픽 분산 및 장애 대응 장치                       |
| WAF                   | 웹 공격을 탐지·차단하는 웹 방화벽                          |
| Reverse Proxy         | 외부 요청을 대신 받아 내부 서버로 전달하는 프록시 서버              |
| Reverse Proxy Cluster | Reverse Proxy 서버들의 클러스터 구성                   |
| External Connector    | 외부 기관 또는 외부 서비스와 연동하는 모듈                     |
| Admin PC              | 관리자 전용 단말                                    |

|                    |                                            |
|--------------------|--------------------------------------------|
| IDS                | 침입 탐지 시스템                                  |
| IPS                | 침입 방지 시스템                                  |
| Fail Count         | 인증 실패 누적 횟수                                |
| Bastion Server     | 관리자 접근 시 반드시 경유해야 하는 보안 게이트 서버             |
| IDOR               | 객체 식별자 조작으로 타인 데이터에 접근하는 취약점               |
| CSRF               | 사용자를 속여 의도하지 않은 요청을 보내게 하는 공격              |
| DB Audit Log       | 데이터베이스 작업 기록 로그                            |
| CSR                | Certificate Signing Request. 인증서 서명 요청 데이터 |
| NTP                | 시스템 시간 동기화 프로토콜                            |
| OWASP              | 웹 애플리케이션 보안 개선 국제 비영리 단체                   |
| DES                | 오래된 대칭키 암호 알고리즘                            |
| Qualys SSL Labs    | SSL/TLS 구성 점검 서비스                          |
| SSH                | 원격 서버 접속용 암호화 프로토콜                         |
| RBAC               | 역할 기반 접근 제어                                |
| SBOM               | 소프트웨어 구성 요소 명세서                            |
| CVE                | 공개 보안 취약점 식별 번호                            |
| RPO                | 허용 가능한 최대 데이터 손실 시간                        |
| ECDSA              | 타원 곡선 기반 전자서명 알고리즘                         |
| RSA                | 대표적인 공개키 암호 알고리즘                           |
| Permanent Redirect | 영구적 URL 이동을 의미하는 HTTP 301 응답               |
| mTLS               | 서버와 클라이언트가 서로 인증하는 TLS                     |
| SSL Strip          | HTTPS 연결을 HTTP로 다운그레이드하는 공격                |
| MITM               | 중간자 공격                                     |

|           |                             |
|-----------|-----------------------------|
| EV-SSL    | 강화된 조직 검증 절차를 거친 TLS 인증서    |
| RC4       | 현재는 사용이 권장되지 않는 스트림 암호 알고리즘 |
| VDI       | 가상 데스크톱 인프라                 |
| SDK       | 소프트웨어 개발 도구 모음              |
| MFA       | 다중 인증                       |
| SAST      | 정적 애플리케이션 보안 테스트            |
| DAST      | 동적 애플리케이션 보안 테스트            |
| RTO       | 서비스 복구 목표 시간                |
| DB Server | 데이터베이스 운영 서버                |

## 6.2. OWASP CWE

### 6.2.1. 인증서 발급 OWASP CWE

[표 49] 인증서 발급 OWASP 취약점 상세 사항

| OWASP | 세부 점검 항목                                  | 취약점 예시                                                      | 취약점 번호                                                                               | OWASP CWE                                                                                                       |
|-------|-------------------------------------------|-------------------------------------------------------------|--------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------|
| A01   | [3] 인증 검증 API 접근 제어 여부                    | 위조 토큰을 이용한 인증 API 직접 호출                                     | CWE-425<br>(Direct Request<br>(‘Forced Browsing’)<br>/ 직접 요청 (‘강제 브라우징’))            | CWE-425<br>(Direct Request<br>(‘Forced Browsing’)<br>/ 직접 요청 (‘강제 브라우징’))                                       |
|       | [5] 타인 계정의 인증 실패 횟수 조회 권한 제어 여부           | 호출 파라미터 변조 시 타인의 인증 실패 횟수 및 계정 잠금 상태를 임의 조회할 위험             | CWE-639<br>(Authorization Bypass Through User-Controlled Key<br>/ 사용자 제어키를 통한 권한 우회) | CWE-639<br>(Authorization Bypass Through User-Controlled Key<br>/ 사용자 제어키를 통한 권한 우회)                            |
|       | [38] 최종 인증 성공 응답 결과에 대한 클라이언트 측 우회 제어 여부  | 서버 측 최종 인가 검증 누락 및 클라이언트 응답 값(성공/실패 status) 변조를 통한 권한 우회 위험 | CWE-287<br>(Improper Authentication<br>/ 부적절한 인증)                                    | CWE-862<br>(Missing Authorization<br>/ 권한 검증 누락)                                                                |
| A-02  | [12] 인증서 상태 검증 통신 구간 내 암호화 채널 통제 여부       | 내부 서버 간 검증 요청 전송 시 암호화 및 설정 미비로 인한 전송 데이터 노출 위험             | CWE-319<br>(Cleartext Transmission of Sensitive Information<br>/ 민감한 정보의 평문 전송)      | CWE-5<br>(J2EE Misconfiguration : Data Transmission Without Encryption<br>/J2EE 잘못된 설정 : 암호화 없는 데이터 전송)         |
|       | [13] CRL 응답 무결성 검증 여부                     | 공격자가 네트워크를 가로채 변조되거나 유효기간이 지난 CRL을 전달해 클라이언트가 정상으로 오인하며 발생  | CWE-347<br>(Improper Verification of Cryptography Signature<br>/ 암호학적 서명의 부적절한 검증)   | CWE-547<br>(Use of Hard-Coded, Security- relevant Constants<br>/ 보안 관련 상수의 하드코딩 사용)                             |
|       | [36] 발급된 토큰 쿠키의 암호화 채널 전송 속성 설정 여부        | 최종 응답 시 반환되는 세션 토큰 쿠키에 보안 속성 미비로 평문 가로채기(Sniffing) 위험       | CWE-922<br>(Insecure Storage of Sensitive Information<br>/ 민감한 정보의 안전하지 않은 저장)       | CWE-614<br>(Sensitive Cookie in HTTPS Session Without ‘Secure’ Attribute<br>/ ‘Secure’ 속성이 없는 HTTPS 세션의 민감한 쿠키) |
| A03   | [12] 외부 연동 검증 모듈 (PKI/CA)의 무결성 및 출처 검증 여부 | 외부 기관 연동 컴포넌트 업데이트 시 무결성 누락으로 인한 악성 변조 모듈 유입 위험             | CWE-353<br>(Missing Support for Integrity Check<br>/ 무결성 검사 지원 누락)                   | CWE-1357<br>(Reliance on Insufficiently Trustworthy Component<br>/ 불충분하게 신뢰할 수 있는 구성 요소에 대한 의존)                 |

|      |                                   |                                                             |                                                                                                                                 |                                                                                                                                              |
|------|-----------------------------------|-------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| A03  | [13] 다운로드 배포 데이터 (CRL)의 무결성 검증 여부 | 외부 배포처로 부터 수신하는 CRL 파일의 출처 및 공급망 무결성 검증 미비로 인한 변조 데이터 신뢰 위험 | CWE-360<br>(Use of Untrusted Input in a Position That Expects a Trustworthy Element<br>/ 신뢰할 수 있는 요소를 기대하는 위치에서 신뢰할 수 없는 입력 사용) | CWE-1104<br>(Use of Unmaintained Third Party Components<br>/ 유지 관리되지 않는 제3자 구성 요소의 사용)                                                       |
|      | [22] 서명 검증 서드파티 라이브러리 취약점 관리 여부   | 금융인증서 서명 검증용 외부 서드파티 모듈 내 알려진 공급망 결함 방치로 인한 로직 우회 위험        | CWE-1395<br>(Dependency on Vulnerable Third-Party Component<br>/ 취약한 제3자 구성요소에 대한 의존성)                                          | CWE-1395<br>(Dependency on Vulnerable Third-Party Component<br>/ 취약한 제3자 구성요소에 대한 의존성)                                                       |
| A-04 | [12] 인증서 체인 및 신뢰 경로의 안전한 검증 여부    | 상위 인증서 체인 검증 미비로 위조 및 만료 인증서를 정상 신뢰할 위험                     | CWE-295<br>(Improper Certificate Validation<br>/ 부적절한 인증서 유효성 검사)                                                               | CWE-296<br>(Improper Following of a Certificate's Chain of Trust<br>/ 인증서 신뢰 체인의 부적절한 추적)                                                    |
|      | [13] 전자서명 검증 로직의 안전성 여부           | 서명 검증 함수 호출 시 해시값 및 부인방지 검증 누락으로 서명이 조작될 위험                 | CWE-347<br>(Improper Verification of Cryptographic Signature<br>/ 암호학적 서명의 부적절한 검증)                                             | CWE-347<br>(Improper Verification of Cryptographic Signature<br>/ 암호학적 서명의 부적절한 검증)                                                          |
|      | [37] 발급 세션 토큰 식별자의 난수 생성 안전성 여부   | 예측 가능한 난수 생성 알고리즘 사용으로 인한 세션 하이재킹 위험                        | CWE-330<br>(Use of Insufficiently Random Values<br>/ 불충분한 난수 값 사용)                                                              | CWE-330<br>(Use of Insufficiently Random Values<br>/ 불충분한 난수 값 사용)                                                                           |
| A-05 | [6] 조회 쿼리 파라미터의 입력 값 검증 여부        | 웹 페이지 요청 시 악의적인 SQL 구문 주입으로 인한 비정상적인 DB 데이터 노출 위험           | CWE-200<br>(Exposure of Sensitive Information to an Unauthorized Actor<br>/ 권한 없는 자에게 민감한 정보 노출)                                | CWE-89<br>(Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')<br>/ SQL 명령에 사용되는 특별한 요소의 부적절한 증화('SQL 삽입')) |

|      |                                                          |                                                                              |                                                                                                                                            |                                                                                                                                            |
|------|----------------------------------------------------------|------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------|
| A-05 | [22] 서명 검증 프레임워크<br>인입 데이터의 구조화 검증<br>여부                 | 인증 요청 파라미터 내 특수 구문<br>주입 및 변조를 통한 로직 우회 위험                                   | CWE-294<br>(Authentication<br>Bypass<br>Capture-replay<br>/ 캡처-재전송을<br>통한 인증 우회)                                                           | CWE-20<br>(Improper Input<br>Validation<br>/ 부적절한 입력<br>검증)                                                                                |
| A06  | 변조 위험이 있는<br>클라이언트 측 데이터의<br>서버 측 재검증 및<br>비보안 의존성 차단 여부 | 브라우저가 보낸 정보의 유효성을<br>서버가 다시 확인하지 않아, 타인의<br>인증서로 조작해 로그인할<br>위험이 있음          | CWE-807<br>(Reliance on<br>Untrusted Inputs<br>in a Security<br>Decision<br>/ 보안 결정 시 신<br>뢰할 수 없는 입력<br>에 의존)                             | CWE-807<br>(Reliance on<br>Untrusted Inputs<br>in a Security<br>Decision<br>/ 보안 결정 시 신<br>뢰할 수 없는 입력<br>에 의존)                             |
|      | DB 조회 에러 또는 데이터<br>부재 시의 예외 차단<br>(Fail-closed) 정책 설계 여부 | 시스템 오류나 데이터베이스 장애로<br>인해 로그인 실패 횟수를 확인하지<br>못할 때, 제한 없이 로그인을 허용할<br>위험이 있음   | CWE-183<br>(Permissive List of<br>Allowed Inputs /<br>허용된 입력에 대<br>한 허용적 목록)                                                               | CWE -693<br>(Protection<br>Mechanism Failure<br>/ 보호 메커니즘<br>실패)                                                                           |
|      | 내부 검증 컴포넌트 간 통신<br>실패 시 예외 차단<br>(Fail-closed) 정책 설계 여부  | 내부 검증 서버가 먹통이 되거나<br>응답이 없을 때, 이를 '정상 인증서'로<br>잘못 판단하여 통과시킬 위험이 있음           | CWE -693<br>(Protection<br>Mechanism Failure<br>/ 보호 메커니즘<br>실패)                                                                           | CWE -693<br>(Protection<br>Mechanism Failure<br>/ 보호 메커니즘<br>실패)                                                                           |
|      | 서명 검증 모듈 연계 시<br>고정 패킷 재사용(Replay)<br>차단 설계 여부           | 인증 요청 값이 매번 똑같은 구조를<br>가지면, 해커가 훔쳐낸 과거의 성공<br>로그인을 그대로 다시 보내 우회할<br>위험이 있음   | CWE-347<br>(Improper<br>Verification of<br>Cryptographic<br>Signature / 암호학<br>적 서명의 부적절<br>한 검증)                                          | CWE-353<br>(Missing Support<br>for Integrity Check<br>/ 무결성 검사 지원<br>누락)                                                                   |
|      | 실패 횟수 증가 연산의<br>비동기 처리 시<br>레이스 컨디션 차단 여부                | 다량의 인증 요청을 동시에 밀어<br>넣을 경우, Fail Count가 누적되기<br>전에 로그인 임계치를 초과<br>대입할 위험이 있음 | CWE-362<br>(Concurrent<br>Execution using<br>Shared Resource<br>with Improper<br>Synchronization /<br>부적절한 동기화가<br>있는 공유 자원을<br>사용한 동시 실행) | CWE-362<br>(Concurrent<br>Execution using<br>Shared Resource<br>with Improper<br>Synchronization /<br>부적절한 동기화가<br>있는 공유 자원을<br>사용한 동시 실행) |
| A07  | 무차별 대입 제한용 식별자<br>기준의 적절성 여부                             | 실패 횟수 제한 기준이 계정이 아닌<br>임시 세션/IP에 귀속되어 잠금 정책이<br>우회됨                          | CWE-307<br>(Improper<br>Restriction of<br>Excessive<br>Authentication<br>Attempts / 과도한<br>인증 시도의 부적<br>절한 제한)                             | CWE-307<br>(Improper<br>Restriction of<br>Excessive<br>Authentication<br>Attempts / 과도한<br>인증 시도의 부적<br>절한 제한)                             |
|      | 인증서 검증 절차 내 사용자<br>신원 일치 여부 단계 존재<br>여부                  | 인증서 자체의 유효성만 검증하고<br>로그인 요청자와의 신원 일치 여부를<br>검증하지 않음                          | CWE-304<br>(Missing Critical<br>Step in<br>Authentication /<br>인증에서 핵심 단<br>계 누락)                                                          | CWE-307<br>(Improper<br>Restriction of<br>Excessive<br>Authentication<br>Attempts / 과도한<br>인증 시도의 부적<br>절한 제한)                             |

|     |                                       |                                                                                           |                                                                                   |                                                                         |
|-----|---------------------------------------|-------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|-------------------------------------------------------------------------|
| A07 | 고정된 인증 요청 패킷에 대한 재사용(Replay) 방어 조치 여부 | 인증 패킷이 고정되어 있어, 탈취된 과거의 정상 성공 서명 값을 그대로 재전송(Replay)하여 인증이 우회될 위험이 있음                      | CWE-294<br>(Authentication Bypass by Capture-replay / 캡처-재전송을 통한 인증 우회)           | CWE-294<br>(Authentication Bypass by Capture-replay / 캡처-재전송을 통한 인증 우회) |
|     | 최종 인증 성공 시 권한 세션 식별자 재발급 여부           | 로그인 완료 후에도 임시 세션 ID가 갱신되지 않고 그대로 고정 사용되어, 세션을 사로채기 당할 위험이 있음                              | CWE-384<br>(Session Fixation / 세션 고정)                                             | CWE-384<br>(Session Fixation / 세션 고정)                                   |
| A08 | 연동 컴포넌트 간 전달되는 검증 데이터의 무결성 검증 여부      | 패킷 암호화 및 변조 검증이 없어, 내부망에서 '폐기' 상태를 '정상'으로 조작하여 인증을 우회할 위험이 있음                             | CWE-353<br>(Missing Support for Integrity Check / 무결성 검사 지원 누락)                   | CWE-353<br>(Missing Support for Integrity Check / 무결성 검사 지원 누락)         |
|     | 암호학적 서명 검증 라이브러리 및 알고리즘의 안전성 여부       | 취약한 암호 알고리즘이나 위조된 검증 모듈을 사용하여, 공격자가 만든 서명 값으로 인증을 우회할 위험이 있음                              | CWE-328<br>(Use of Weak Hash / 취약한 해시 사용)                                         | CWE-353<br>(Missing Support for Integrity Check / 무결성 검사 지원 누락)         |
|     | 데이터베이스 반영 트랜잭션 데이터의 상태 무결성 보장 여부      | 데이트 업데이트 시 입력값 검증이 누락되어, 쿼리 조작을 통해 실패 횟수를 임의로 초기화할 위험이 있음                                 | CWE-345<br>(Insufficient Verification of Data Authenticity / 데이터 진위의 불충분한 검증)     | CWE-353<br>(Missing Support for Integrity Check / 무결성 검사 지원 누락)         |
| A09 | 민감한 인증 정보의 로그 노출 제어 여부                | 로그 과정에서 평문 비밀번호나 서명키 등 중요 정보의 마스킹이 누락되어, 로그를 통해 인증 데이터가 유출될 위험이 있음                        | CWE-532<br>(Insertion of Sensitive Information into Log File / 로그인 파일에 민감한 정보 삽입) | CWE-778<br>(Insufficient Logging / 불충분한 로깅)                             |
|     | 인증 실패 로그의 무결성 보장 및 위변조 방지 여부          | 감사 로그 인프라의 수정/삭제 권한 통제 미비로 인해, 공격자가 무차별 대입 흔적을 말소하여 침입 탐지를 무력화할 위험이 있음                    | CWE-117<br>(Improper Output Neutralization for Logs / 로그에 대한 부적절한 출력 중화)          | CWE-778<br>(Insufficient Logging / 불충분한 로깅)                             |
|     | 모니터링 및 실시 간 알림 시스템 연계 여부              | 실시간 보안 관제 및 알림 체계가 누락되어, 로그 분석을 통한 비정상 침입 시도의 적시 탐지가 불가능함                                 | CWE-778<br>(Insufficient Logging / 불충분한 로깅)                                       | CWE-778<br>(Insufficient Logging / 불충분한 로깅)                             |
| A10 | 내부 라우팅 목적지 주소에 대한 변조 차단 및 검증 여부       | 라우팅 URL 필터링 부재로 목적지 주소를 변조하여 내부 비공개 API로 요청을 위조 전송할 위험이 있음                                | CWE-918<br>(Server-Side Request Forgery / 서버 측 요청 위조)                             | CWE-918<br>(Server-Side Request Forgery / 서버 측 요청 위조)                   |
|     | 내부 컴포넌트 간 호출 경로 및 파라미터의 변조 차단 여부      | 내부 서버를 호출 할 때 연결 주소를 검증하지 않아, 공격자가 이 주소를 조작하여 외부에서 접근할 수 없는 내부 DB 등 핵심 시스템에 불법 접근할 위험이 있음 | CWE-918<br>(Server-Side Request Forgery / 서버 측 요청 위조)                             | CWE-918<br>(Server-Side Request Forgery / 서버 측 요청 위조)                   |

## 6.2.2. 인증서 검증 OWASP CWE

[표 50] 인증서 검증 OWASP 취약점 상세 사항

| OWASP | 세부 점검 항목                                  | 취약점 예시                                                                        | 취약점 번호                                                                    | OWASP CWE                                                                 |
|-------|-------------------------------------------|-------------------------------------------------------------------------------|---------------------------------------------------------------------------|---------------------------------------------------------------------------|
| A01   | [3] API 호출 시 인증 검증 여부                     | 비대면 본인 확인 우회 및 인증값 변조                                                         | CWE-862 Missing Authorization (권한 검증 누락)                                  | CWE-862 Missing Authorization (권한 검증 누락)                                  |
|       | [43] 인증 완료 후 발급 프로세스 이관 시 권한 검증 여부        | 앞선 인증(SMS/ARS/OTP) 성공 여부 미검증으로 인한 인증 단계 우회 및 발급 단계 강제 진입 위험.                  | CWE-862 Missing Authorization (권한 검증 누락)                                  | CWE-862 Missing Authorization (권한 검증 누락)                                  |
| A02   | [15] SMS 서버 연계 구간 회원 정보 반환 시 구간 암호화 적용 여부 | SMS 서버 연계 구간 암호화 누락으로 내부망 패킷 감청 시 개인정보 평문 노출 위험.                              | CWE-319 (민감 정보의 평문 전송)                                                    | CWE-5 (암호화 없는 데이터 전송)                                                     |
|       | [24] ARS 서버 연계 구간 회원 정보 반환 시 구간 암호화 적용 여부 | ARS서버 연계 구간 암호화 누락으로 내부망 패킷 감청 시 개인정보 평문 노출 위험.                               | CWE-319 (민감 정보의 평문 전송)                                                    | CWE-5 (암호화 없는 데이터 전송)                                                     |
|       | [53] 발급 결과 응답 데이터 전송 시 암호화 적용 여부          | 외부 응답 데이터 평문 전송으로 네트워크 패킷 감청 시 인증서 핵심 정보 노출 위험.                               | CWE-319 (민감 정보의 평문 전송)                                                    | CWE-5 (암호화 없는 데이터 전송)                                                     |
| A03   | [30] OTP 서버 모듈 최신화 여부                     | 노후화된 외부 모듈 사용으로 이미 공개된 취약점(CVE) 기반 서버 침해 위험.                                  | CWE-1395 Dependency on Vulnerable Third-Party Component (취약한 제3자 컴포넌트 의존) | CWE-1395 Dependency on Vulnerable Third-Party Component (취약한 제3자 컴포넌트 의존) |
|       | [44] 인증서(Certificate) 생성 요청 시 외부 모듈 검증 여부 | 인증서 생성 라이브러리의 고유 취약점(CVE)으로 인한 암호키 유출 및 시스템 권한 탈취 위험.                         | CWE-1395 Dependency on Vulnerable Third-Party Component (취약한 제3자 컴포넌트 의존) | CWE-1395 Dependency on Vulnerable Third-Party Component (취약한 제3자 컴포넌트 의존) |
| A04   | [31] OTP Secret Key 조회 시 암호화 적정성          | 서버 간 OTP 비밀키(Secret Key) 동기화 및 검증 시 하드코딩된 암호키를 사용하거나 취약한 대칭키 알고리즘을 사용할 위험이 있음 | CWE-321 (하드코딩된 암호키 사용)                                                    | CWE-321 (하드코딩된 암호키 사용)                                                    |
|       | [44] 인증서 생성 요청 데이터 무결성 검증 여부              | 서명 검증 누락으로 인한 인증 데이터 변조 및 위조 인증서 생성 위험                                        | CWE-347 (암호화 서명 검증 미비)                                                    | CWE-347 (암호화 서명 검증 미비)                                                    |
|       | [45] 인증서 생성 시 암호화 알고리즘 적정성                | 취약한 암호 알고리즘 사용으로 인한 인증서 위변조 및 복호화 위험.                                         | CWE-327 (취약한 암호화 알고리즘 사용)                                                 | CWE-327 (취약한 암호화 알고리즘 사용)                                                 |
| A05   | [3] API 입력값 검증 여부                         | API 입력값의 크기나 개수에 대한 최대 범위를 검증하지 않아 서버가 마비                                     | CWE-20 (부적절한 입력값 검증)                                                      | CWE-20 (부적절한 입력값 검증)                                                      |
|       | [4] 요청 데이터 검증 여부                          | 숫자 범위 검증 누락과 문자열 데이터 형식 검증 누락                                                 | CWE-20 (부적절한 입력값 검증)                                                      | CWE-20 (부적절한 입력값 검증)                                                      |
|       | [4] 본인인증 요청 데이터 무결성 검증 여부                 | 외부입력값을 이용한 LDAP 조작 (LDAP 인젝션 공격)                                              | CWE-90 (LDAP 인젝션)                                                         | CWE-90 (LDAP 인젝션)                                                         |

|     |                                           |                                                                  |                                                                                    |                                                                                                                   |
|-----|-------------------------------------------|------------------------------------------------------------------|------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| A06 | API 다이렉트 호출 방지 및 접근 순서 강제 설계 여부           | UI 경로를 거치지 않는 직접 호출 제어 미비로 인해, 정상 프로세스를 우회 하여 과정을 시작할 위험이 있음     | CWE-424<br>(Improper Protection of Alternate Path / 대안 경로에 대한 부적절한 보호)             | CWE-841<br>(Improper Enforcement of Behavioral Workflow / 행동 워크플로의 부적절한 시행)                                       |
|     | 비즈니스 로직 우회를 차단하는 선행 검증 설계 여부              | DB 에러 시 실패 횟수를 0으로 인식하는 결함으로 인해, 누적 실패에 따른 계정 잠금 정책이 무력화될 위험이 있음 | CWE-183<br>(Permissive Behavior by Default / 기본적으로 허용하는 동작)                        | CWE-693<br>(Protection Mechanism Failure / 보호 매커니즘 오류)                                                            |
|     | 발송 요청 횟수 제한 이키텍처 설계 여부                    | API 발송 요청 제한 누락으로 인해, 대량 호출 공격 시 통신 비용 폭탄 및 문자 폭탄 공격에 노출될 위험이 있음 | CWE-770<br>(Allocation of Resources Without Limits or Throttling / 제한 없는 자원 할당)    | CWE-799<br>(Improper Control of Interaction Frequency / 상호 작용 빈도의 부적절한 제어)                                        |
|     | 다중 인증 수단 간 독립적 상태 관리 설계 여부                | 인증 수단 전환 시 실패 카운트가 초기화되는 결함으로 인해, 무차별 대입 시도 기회가 비정상 증가할 위험이 있음   | CWE-1188<br>(Insecure Default Initialization of Resource / 자원의 안전하지 않은 초기화)        | CWE-841<br>(Improper Enforcement of Behavioral Workflow / 행동 워크플로의 부적절한 시행)                                       |
|     | 다중 식별자 결합 검증 (Multi-factor Binding) 설계 여부 | OTP 조회 시 사용자 ID와의 매핑 검증 누락으로 인해, 타인의 유효한 OTP로 인증을 우회할 위험이 있음     | CWE-353<br>(Missing Missing Multi-Factor Authentication Binding / 다중 식별자 결합 검증 누락) | CWE-807<br>(Reliance on Untrusted Inputs in a Security Decision / 보안 결정 시 신뢰할 수 없는 입력에 대한 의존)                     |
|     | 레이어 간 단방향 토큰 검증 (One-time Token) 구조 설계 여부 | 이관 패킷 재사용 방어 미비로 인해, 유효 토큰을 가로채 재전송하여 인증서를 중복 발급받을 위험이 있음        | CWE-840<br>(Business Logic Errors / 비즈니스 로직 오류)                                    | CWE-841<br>(Improper Enforcement of Behavioral Workflow / 행동 워크플로의 부적절한 시행)                                       |
|     | 비동기 작업 처리에 따른 트랜잭션 완결성 설계 여부              | 트랜잭션 원자성 설계 누락으로 인해, DB 오류 시 발급은 됐으나 계정은 잠겨있는 데이터 불일치 위험이 있음     | CWE-413<br>(Improper Resource Locking / 부적절한 자원 잠금 및 원자성 결여)                       | CWE-362<br>(Concurrent Execution using Shared Resource with Improper Synchronization/ 부적절한 동기화로 인한 공유 리소스의 동시 실행) |
| A07 | 사용자 식별 정보(ID) 유효성 선행 검증 여부                | 무효 ID 입력 시 에러 없이 실패 횟수를 0으로 처리하여, 비정상 계정으로 인증 단계에 진입할 위험이 있음.    | CWE-20<br>(Improper Input Validation / 부적절한 입력값 검증)                                | CWE-303<br>(Incorrect Implementation of Authentication Algorithm / 인증 알고리즘의 잘못된 구현)                               |

|     |                                                |                                                                   |                                                                                           |                                                                                           |
|-----|------------------------------------------------|-------------------------------------------------------------------|-------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|
| A07 | 세션 다중화를 이용한 무차별 대입 차단 여부                       | 실패 제한 정책이 동일 세션 내에만 적용되어, 쿠키를 새로 변조/삭제하며 대입 공격을 무한 시도할 위험이 있음.    | CWE-307<br>(Improper Restriction of Excessive Authentication Attempts / 과도한 인증 시도 제한 미비)  | CWE-307<br>(Improper Restriction of Excessive Authentication Attempts / 과도한 인증 시도에 대한 미비) |
|     | OTP 일회용성 (Replay Attack 방지) 보장 여부              | 이미 인증에 성공한 OTP 코드를 유효시간 내에 재사용(Replay)하여 인증을 우회할 위험이 있음.          | CWE-294<br>(Authentication Bypass by Catching and Replaying a Message / 패킷 재전송을 통한 인증 우회) | CWE-294<br>(Authentication Bypass by Catching and Replaying a Message / 패킷 재전송을 통한 인증 우회) |
|     | 최종 이관 단계에서의 사용자 세션 고정 (Session Fixation) 방지 여부 | 최초 본인인증 세션 ID가 최종 발급까지 그대로 유지되어, 세션 가로채기를 통해 발급 권한을 탈취당할 위험이 있음.  | CWE-384<br>(Session Fixation / 세션 고정)                                                     | CWE-384<br>(Session Fixation / 세션 고정)                                                     |
| A08 | DB 조회 결과 데이터 객체의 신뢰성 및 역직렬화 무결성 검증 여부          | 내부 데이터 유통 시 검증 누락으로 중간 변조를 통한 타인 정보 주입 위험이 있음.                    | CWE-345<br>(Insufficient Verification of Data Authenticity / 데이터 진위 검증 미흡)                | CWE-345<br>(Insufficient Verification of Data Authenticity / 데이터 진위 검증 미흡)                |
|     | 내부 연동 정보 객체의 변조 방지 및 검증 여부                     | 스키마 검증 누락으로 조작된 직렬화 데이터 주입 시 시스템 오작동 위험이 있음.                      | CWE-502<br>(Deserialization of Untrusted Data / 신뢰할 수 없는 데이터의 역직렬화)                       | CWE-502<br>(Deserialization of Untrusted Data / 신뢰할 수 없는 데이터의 역직렬화)                       |
|     | 클라이언트 생성 요청서 (CSR) 표준 포맷의 위변조 검증 여부            | 수신한 CSR 서명 검증 누락으로 식별 정보가 조작된 위조 인증서가 발급될 위험이 있음.                 | CWE-347<br>(Improper Verification of Cryptographic Signature / 암호학적 서명의 부적절한 검증)          | CWE-345<br>(Insufficient Verification of Data Authenticity / 데이터 진위 확인 불충분)               |
|     | 시스템 컴포넌트 간 발급 상태 전이 데이터의 신뢰성 검증 여부             | 전송 구간 무결성 미비로 정상 인증서의 상태 값이 폐기 등으로 위변조되어 서비스가 마비될 위험이 있음.         | CWE-345<br>(Insufficient Verification of Data Authenticity / 데이터 진위 검증 미흡)                | CWE-345<br>(Insufficient Verification of Data Authenticity / 데이터 진위 검증 미흡)                |
| A09 | 특정 계정의 무차별 대입 공격에 대한 실시간 경보 (Alerting) 설계 여부   | 연속 실패 등 해킹 징후가 발생해도 실시간 알림이 울리지 않아, 공격자가 차단 없이 공격을 지속할 위험이 있음.    | CWE-778<br>(Insufficient Logging / 불충분한 로깅)                                               | CWE-778<br>(Insufficient Logging / 불충분한 로깅)                                               |
|     | 로그 인젝션 방지를 위한 입력값 정제 여부                        | 로그 기록 시 입력값 검증이 없어, 공격자가 의도적으로 조작한 특수문자를 밀어 넣어 감사 로그를 변조할 위험이 있음. | CWE-117<br>(Improper Output Handling for Logs / 부적절한 로그 출력 처리)                            | CWE-117<br>(Improper Output Handling for Logs / 부적절한 로그 출력 처리)                            |

|     |                                          |                                                                         |                                                                                                   |                                                                                                   |
|-----|------------------------------------------|-------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| A09 | 사후 추적용 필수 식별 정보 (IP, 환경 등)의 기록 여부        | 로그에 단순 실패 결과만 남고 IP나 타임스탬프 등이 누락되어, 해킹 사고 발생 시 추적이나 IP 차단이 불가능할 위험이 있음. | CWE-778<br>(Insufficient Logging / 불충분한 로깅)                                                       | CWE-223<br>(Omission of Security-relevant Information / 보안 관련 정보 누락)                              |
|     | 분산 서버 간 표준 시간 동기화(NTP) 설정 여부             | 서버 간 시간 동기화(NTP)가 미비하여 로그 타임스탬프가 어긋날 경우, 시간대별 공격 흐름을 분석하기 어려울 위험이 있음.   | CWE-1244<br>(Internal Clock Throttling or Synchronization Component / 내부 클록 동기화 부재)               | CWE-223<br>(Omission of Security-relevant Information / 보안 관련 정보 누락)                              |
|     | 로그 DB 계정의 수정·삭제 권한 차단(Append-Only) 여부    | 서버가 로그 DB에 대한 수정/삭제 권한까지 가지면, 서버 해킹 시 공격자가 발급 조작 흔적을 지우고 도망갈 위험이 있음.    | CWE-276<br>(Incorrect Default Permissions / 부적절한 기본 권한 설정)                                        | CWE-778<br>(Insufficient Logging / 불충분한 로깅)                                                       |
| A10 | 잠금 처리 중 에러 발생 시 차단(Fail-closed) 상태 유지 여부 | 계정 잠금 처리 중 에러가 나면 잠금이 풀려, 대입 공격이 계속될 위험이 있음.                            | CWE-755<br>(Improper Handling of Exceptional Conditions / 예외 조건의 부적절한 처리)                         | CWE-755<br>(Improper Handling of Exceptional Conditions / 예외 상황의 부적절한 처리)                         |
|     | 에러 화면 내 민감 정보 (스택 트레이스) 노출 차단 여부         | 에러 발생 시 상세 소스코드 경로가 노출되어, 공격 힌트를 제공할 위험이 있음.                            | CWE-209<br>(Generation of Error Message Containing Sensitive Information / 민감한 정보가 포함된 에러 메시지 생성) | CWE-209<br>(Generation of Error Message Containing Sensitive Information / 민감한 정보가 포함된 오류 메시지 생성) |
|     | 예외 블록 내 인증 변수의 안전한 초기화(false) 여부         | 에러 발생 시 변수 초기화 오류로 인증 체크를 건너뛰고 로그인될 위험이 있음.                             | CWE-252<br>(Unchecked Return Value / 반환값 미검증)                                                     | CWE-252<br>(Unchecked Return Value / 확인되지 않은 반환 값)                                                |
|     | 연계 서버 통신 타임아웃 발생 시 인증 실패 강제 처리 여부        | 연계 서버 통신 장애(타임아웃) 시 에러를 무시하고 다음 단계로 진입할 위험이 있음.                         | CWE-391<br>(Unchecked Error Condition / 에러 조건 미검증)                                                | CWE-391<br>(Unchecked Error Condition / 확인되지 않은 오류 조건)                                            |
|     | 프로세스 예외 종료 시 할당된 시스템 자원의 완전한 해제 여부       | 에러 발생 시 DB 커넥션 등이 닫히지 않고 누수되어, 서버가 다운될 위험이 있음.                          | CWE-404<br>(Improper Resource Shutdown or Release / 부적절한 자원 종료 및 해제)                              | CWE-460<br>(Improper Cleanup on Thrown Exception / 예외 발생 시 부적절한 정리 작업)                            |